



EKAGRA

AI-Based Detection of Cyber Threats in Unidirectional IP Traffic

Technical design, experimental evidence and business case

PROBLEM STATEMENT	SIH26145
ORGANISATION	National Technical Research Organisation (NTRO)
THEME	Blockchain & Cybersecurity
CATEGORY	Software
TEAM	AlgoRhythms
INSTITUTION	
SUBMITTED	September 2026

Every measurement in this report is reproducible from the project repository; every external figure is cited to a named source.

CONTENTS**Table of contents**

Certificate	8
Declaration	9
Acknowledgement	10
Abstract	11
How this report is organised	12
PART I The problem and the solution	13
1. Introduction	14
1.1 Background: monitoring what you cannot talk to	14
1.2 Motivation	14
1.3 Problem statement	14
1.4 Research question	15
1.5 Objectives	15
1.6 Scope	16
1.7 Contributions	16
2. Existing systems and the gap	17
2.1 Academic work	17
2.2 The dataset problem, and what we did about it	17
2.3 Operational tools in use today	18
2.4 The gap, stated precisely	18
3. Requirements	19
3.1 Functional requirements	19
3.2 Non-functional requirements	19
3.3 Constraints and assumptions	19
PART II Technical design, implementation and evidence	21
4. System architecture	22
4.1 Principles	22
4.2 Stages and responsibilities	23
4.3 Technology choices and their justification	24
4.4 Streaming with bounded latency and bounded memory	24
5. Detection methodology	25
5.1 Visibility profiling: the step most pipelines skip	25

5.2 The central finding: memory, not direction	25
5.3 The sixteen host-window features	26
5.4 Protocol evidence without decryption	26
5.5 The six detector heads	27
5.6 Severity, kept separate from confidence	27
6. Uncertainty, calibration and abstention	28
6.1 Why a diode sensor must be able to decline	28
6.2 Split-conformal prediction	28
6.3 Why Mondrian, and a failure along the way	28
6.4 What abstention means for the operator	29
7. Evidence, integrity and the threat model	30
7.1 What an alert has to prove	30
7.2 Canonicalisation: the part that is easy to get wrong	30
7.3 Threat model	31
7.4 Independent verification in the browser	31
7.5 The limit, stated	33
8. Implementation	34
8.1 Repository layout	34
8.2 Scale of the implementation	34
8.3 Algorithms worth naming	34
8.4 Sharding, and an honest result	35
8.5 The read-only API and the console	35
9. Experimental programme and results	36
9.1 Method: pre-registration	36
9.2 The headline measurement	36
9.3 The stress test that narrowed it further	37
9.4 Performance	38
9.5 Domain-generation algorithms: the weakest class	38
9.6 Every refuted prediction	39
10. Verification, testing and quality	40
10.1 Test strategy	40
10.2 Constraints enforced by the build	40
10.3 Results	40
PART III The business case	41

11. Market and opportunity	42
11.1 Who is obliged to solve this problem	42
11.2 The problem is growing, and it is measured	42
11.3 Market size	43
11.4 Why now	43
12. Competitive landscape and positioning	44
12.1 Feature comparison	44
12.2 What is defensible, and what is not	45
13. Business model, pricing and cost	46
13.1 Model: open core with paid assurance	46
13.2 Cost of ownership	46
13.3 Unit economics of an enclave	47
14. Go-to-market and deployment	48
14.1 Where the system physically sits	48
14.2 Adoption path	48
14.3 Route to the customer	48
14.4 What would make a pilot fail, and how we would know early	49
15. Risk register	50
16. Compliance, standards and intellectual property	51
16.1 Indian legal and regulatory context	51
16.2 Technical standards used	51
16.3 Intellectual property and licensing	51
16.4 Data protection	52
17. Impact and national alignment	53
17.1 Who benefits, and how	53
17.2 National and sustainable-development alignment	53
17.3 An analyst's day, before and after	53
PART IV Execution, limitations and conclusion	54
18. Project execution	55
18.1 How the work was organised	55
18.2 Working method	55
18.3 Effort profile	55
19. Limitations and future scope	56
19.1 Limitations, in full	56

19.2 Roadmap	56
20. Conclusion	58
References	59
APPENDIX A: Glossary and full forms	60
APPENDIX B: Problem-statement compliance matrix	62
APPENDIX C: Reproduction guide	63
APPENDIX D: Evidence bundle schema	64
APPENDIX E: The pre-registered prediction register	65
APPENDIX F: Anticipated questions	66

FIGURES

List of figures

Figure 1. The deployment the problem statement describes. Traffic copies flow to ...	14
Figure 2. The eight-stage pipeline. Highlighted stages are the three that make ...	22
Figure 3. The same traffic seen per connection and per host. Fan-out over a ...	25
Figure 4. Abstention as a calibrated decision. The threshold is learned from ...	28
Figure 5. Conformal calibration measured on real traffic: per-class coverage ...	29
Figure 6. The hash chain. Editing one stored alert breaks its own seal and every ...	30
Figure 7. Chain verified: 400 entries re-hashed inside the browser, every link ...	32
Figure 8. After one stored alert is edited: the break is located at the exact ...	32
Figure 9. 877,801 real flows, temporal split, addresses excluded. Left: ...	37
Figure 10. As attacks become more diffuse, one-way per-flow features track full ...	37
Figure 11. Two adjacent markets. Network detection and response is the capability ...	43
Figure 12. The two axes that matter for this buyer: can the product detect threats ...	44
Figure 13. Five-year cumulative cost for one enclave under the stated assumptions. ...	46
Figure 14. Deployment topology. The sensor and console live entirely inside the ...	48
Figure 15. Sequence and dependencies. Teal items are engineering we can complete ...	56

TABLES

List of tables

Table 1. How this report is organised	12
Table 2. Objectives	15
Table 3. Scope	16
Table 4. Operational tools in use today	18
Table 5. Functional requirements	19
Table 6. Non-functional requirements	19
Table 7. Stages and responsibilities	23
Table 8. Technology choices and their justification	24
Table 9. The sixteen host-window features	26
Table 10. Protocol evidence without decryption	27
Table 11. The six detector heads	27
Table 12. Why Mondrian, and a failure along the way	28
Table 13. Threat model	31
Table 14. Algorithms worth naming	34
Table 15. The read-only API and the console	35

Table 16. Method: pre-registration	36
Table 17. The headline measurement	37
Table 18. Performance	38
Table 19. Domain-generation algorithms: the weakest class	38
Table 20. Every refuted prediction	39
Table 21. Test strategy	40
Table 22. Who is obliged to solve this problem	42
Table 23. Market size	43
Table 24. Feature comparison	44
Table 25. What is defensible, and what is not	45
Table 26. Model: open core with paid assurance	46
Table 27. Cost of ownership	47
Table 28. Adoption path	48
Table 29. What would make a pilot fail, and how we would know early	49
Table 30. Risk register	50
Table 31. Indian legal and regulatory context	51
Table 32. Who benefits, and how	53
Table 33. An analyst's day, before and after	53
Table 34. How the work was organised	55
Table 35. Roadmap	57
Table 36. APPENDIX A: Glossary and full forms	61
Table 37. APPENDIX B: Problem-statement compliance matrix	62
Table 38. APPENDIX E: The pre-registered prediction register	65

Certificate

This is to certify that the project entitled **EKAGRA - AI-Based Detection of Cyber Threats in Unidirectional IP Traffic**, submitted against problem statement **SIH26145** of the National Technical Research Organisation (NTRO) under the theme Blockchain & Cybersecurity, is the bona fide work of Team **AlgoRhythms**, carried out for the Smart India Hackathon 2026.

The work described in this report was carried out by the team members named below under the guidance of the mentor named below, and has not been submitted elsewhere for the award of any degree or diploma.

Team leader

Mentor

Head of Department / SPOC

Declaration

We declare that this report and the software it describes are our own work. Third-party datasets, libraries and published results are credited in the References. Every measurement reported here was produced by code in our repository and can be reproduced with the commands in Appendix D.

We further declare that we report our failures as prominently as our successes. Forty-two predictions were written into our experiment files before those experiments were first run; seventeen of them were refuted, including the claim this project was originally built around. All seventeen are listed in Chapter 9, and none of the original predictions were edited after the fact.

Team leader

Team member

Team member

Acknowledgement

We thank the National Technical Research Organisation for a problem statement that is unusually well posed: it names a deployment constraint, states what is out of scope, and leaves the method open. That combination is what made a measurable research question possible.

We thank the authors of the CIC-IDS2017 dataset at the Canadian Institute for Cybersecurity, and Engelen, Rimmer and Joosen, whose published audit of that dataset's defects led us to the corrected re-extraction we used throughout. We thank our institution's Smart India Hackathon coordinators for logistics and review, and our mentor for insisting that every claim in this report carry the control that narrows it.

Abstract

Networks that matter most - defence, power grid control, classified government systems - are monitored through a **data diode**: hardware that lets a copy of the traffic out to a monitoring enclave and allows nothing back. A sensor in that enclave never observes replies, cannot query a reputation service, cannot probe a host and cannot block anything. Detection methods and public datasets almost universally assume two-way visibility, so a conventionally trained detector degrades sharply when deployed there. Until now, how sharply, and why, had not been measured.

This report presents **EKAGRA**, a streaming threat-detection sensor built for that constraint, and the experimental programme behind it. On 877,801 real flows from the corrected CIC-IDS2017 re-extraction, with a temporal split and source and destination addresses excluded, a conventional detector falls from **0.9793** to **0.6903** binary F1 when restricted to one direction. Our central finding is that the loss is not caused by the missing direction but by missing **per-host state**: a sensor that maintains sixteen host-window aggregates over a 60-second window scores **0.9810** on the same one-way traffic, matching full visibility. A control experiment showed those sixteen features alone reach 0.9812, which narrowed our own headline claim; a further experiment showed they collapse when attacks are slow and diffuse, which is why the shipped sensor keeps per-flow evidence alongside them.

EKAGRA covers the six threat classes named in the problem statement, attaches a severity and a conformally calibrated confidence to every alert, and **abstains** rather than guessing when the evidence is weak (9.11% of cases, with 99.55% accuracy on the remainder). Every alert is sealed into a SHA-256 hash chain with a per-bundle HMAC, which an analyst re-verifies inside an air-gapped browser console; seven tests attack that chain, including a full forward re-forge. The system sustains 610 to 672 Mbps on commodity hardware, holds 2.66 MB of state for 14,817 hosts, and emits alerts within 75 seconds. It passes 290 automated tests, of which several fail the build if any component in the detection path can open a network socket.

The report also sets out the commercial case: an addressable market anchored on NCIIPC's eight critical sectors, a positioning analysis against open-source IDS, commercial NDR platforms and diode vendors, an open-core business model with a five-year cost comparison, a go-to-market path through pilot deployment and government procurement, a risk register, and the compliance context created by the IT Act and CERT-In's 2022 directions.

Keywords: unidirectional network monitoring, data diode, network intrusion detection, streaming host-window features, conformal prediction, selective classification, tamper-evident evidence, JA4, QUIC, CIC-IDS2017, critical information infrastructure.

How this report is organised

The deck is six slides and the demonstration video is two minutes. Neither can carry a method, a threat model or a cost model. This report is written to be the place where those live, and it is organised so a reader can enter at the depth they need.

Part	Chapters	For the reader who wants
I - Problem and solution	1 to 3	the deployment constraint, what already exists and why it fails, and the requirements we held ourselves to
II - Technical	4 to 10	architecture, detection method, calibration, evidence integrity, implementation, results, and how the system is verified
III - Business	11 to 17	market, competition, business model and cost, go-to-market, risk, compliance and national impact
IV - Execution and closing	18 to 20	how the work was run, what remains, and the conclusion
Appendices	A to F	glossary, problem-statement compliance, reproduction guide, API and evidence schema, the full prediction register, and anticipated questions

Table 1. How this report is organised

A NOTE ON NUMBERS

Every figure in this report is measured by code in the repository, or cited to a named external source. Where a number is an assumption - as in the cost model of Chapter 13 - the assumption is stated on the page so it can be challenged. Nothing here is projected from a number we did not measure.



PART I

The problem and the solution

CHAPTER 1

Introduction

1.1 Background: monitoring what you cannot talk to

A **data diode** is a physical one-way link. Light travels down a fibre in one direction and there is no return path at all - not a firewalled one, not a rate-limited one: none. Organisations use diodes when a network is too sensitive to risk any inbound route, but still needs to be watched. The diode copies traffic out to a monitoring enclave, and an attacker who compromises the enclave gains nothing that leads back in.

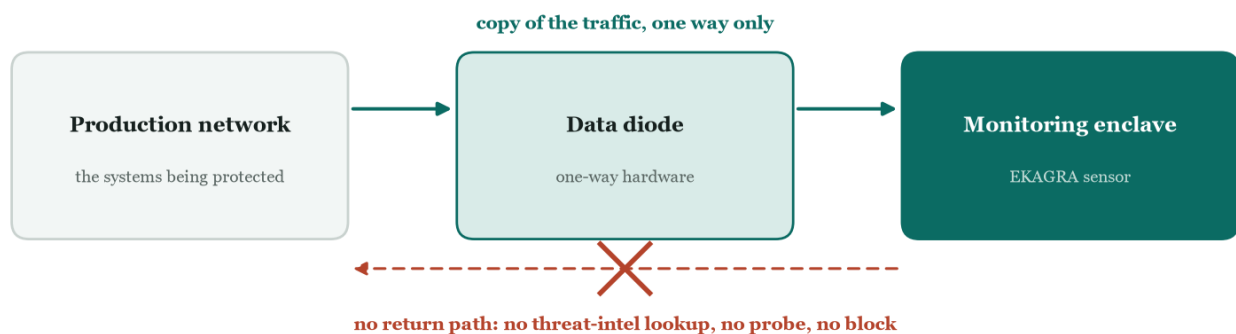


Figure 1. The deployment the problem statement describes. Traffic copies flow to the monitoring enclave; no query, probe or block can flow back.

The security property is absolute, and so is its cost to detection. A sensor behind the diode sees only one side of every conversation. It never sees the SYN-ACK that would confirm a connection, the NXDOMAIN that would betray a domain-generation algorithm, the RST that reveals a closed port, or the certificate that identifies a server. It cannot enrich an observation with a reputation lookup, because the lookup is an outbound connection. It cannot verify a suspicion by probing the host. It cannot block. It observes, decides, and records - alone.

1.2 Motivation

Two things motivated this project. First, every widely used intrusion-detection dataset (CIC-IDS2017, CSE-CIC-IDS2018, UNSW-NB15) ships *bidirectional* flow records, and most published pipelines assume enrichment is available. A detector trained on those records and deployed behind a diode is being asked to work on inputs unlike anything it saw in training, and nobody can tell it that it is wrong, because no feedback path exists.

Second, the failure is silent. A detector starved of its usual signals does not announce that it has been blinded; it keeps emitting confident labels. In an enclave with no return path, an unchallengeable wrong answer is worse than an honest refusal to answer. That observation shaped two of this system's defining features: calibrated abstention, and evidence that can be checked independently after the fact.

1.3 Problem statement

Problem statement SIH26145, issued by the National Technical Research Organisation, asks for AI-based detection of cyber threats in unidirectional IP traffic. Its operative constraints, quoted:

"The enclave can see everything crossing the link, but it has no physical or protocol-level path back into the production network."

"Treat the input as strictly read-only. Any design that assumes a return path, a live query to the source, or an inline block is out of scope."

"TLS/QUIC sessions must be analysed from metadata only." ... "must process traffic incrementally and raise alerts with bounded latency"

It names six threat classes - volumetric and protocol denial of service, command-and-control beaconing, domain-generation algorithms and DNS tunnelling, malware inside encrypted sessions, reconnaissance and scanning, and data exfiltration - and requires each alert to carry a severity and a confidence. Appendix B maps every clause to the component that satisfies it, including the one clause we have not yet satisfied.

1.4 Research question

Stated so that it can be answered with an experiment rather than an opinion: **how much detection performance does a one-way tap actually cost, and which part of the lost visibility causes the cost?** The answer determines the design. If the cost comes from the missing direction itself, the only remedies are better priors or more data. If it comes from something the sensor could have kept but did not, the remedy is engineering - and the diode constraint stops being an excuse.

1.5 Objectives

#	Objective	Where it is addressed	Status
O1	Quantify the cost of one-way visibility on real traffic, with controls	Ch 9.2	Met: 0.9793 to 0.6903
O2	Identify the cause of that cost and recover it	Ch 5.2, 9.2	Met: per-host state, 0.9810
O3	Detect all six named threat classes from one direction only	Ch 5.5	Met
O4	Process traffic as a stream with bounded latency and bounded memory	Ch 4.4, 6	Met: 75 s, 2.66 MB / 14,817 hosts
O5	Attach severity and calibrated confidence; abstain when evidence is weak	Ch 6	Met: 9.11% abstention
O6	Make every alert provable and tamper-evident	Ch 7	Met: chain + HMAC, 7 attack tests
O7	Enforce the read-only constraint mechanically, not by convention	Ch 10.2	Met: CI fails the build
O8	Publish refutations of our own claims alongside confirmations	Ch 9.7	Met: 17 of 42 refuted

Table 2. Objectives

1.6 Scope

In scope	Out of scope, and why
Passive analysis of mirrored or diode-delivered traffic	Inline blocking: excluded by the problem statement
Metadata of encrypted sessions: handshakes, sizes, timings	Payload decryption: excluded, and unnecessary for the six classes
Six threat classes with severity and calibrated confidence	Endpoint telemetry and host agents: no path to install or collect them
Tamper-evident evidence and offline verification	Long-term SIEM storage and correlation: a different product category
An analyst console that runs fully air-gapped	Authentication and user roles: the enclave is already access-controlled (a recorded decision, revisited in Ch 15)

Table 3. Scope

1.7 Contributions

1. **A measurement.** The cost of one-way visibility on 877,801 real flows, with the control experiments that attribute it to per-host state rather than to direction.
2. **A sensor built to a measured visibility profile** rather than to a dataset's convention, covering six threat classes in a single streaming pass.
3. **Calibrated abstention as a first-class output**, with a distribution-free guarantee and per-class thresholds, for a setting where a wrong answer cannot be corrected.
4. **Evidence that survives its own author:** a hash chain plus keyed HMAC, verified independently in the browser, with a stated threat model and a stated limit.
5. **A pre-registered experimental record:** 42 predictions fixed before their runs, 17 refuted and published, including the claim the project was named for.

CHAPTER 2

Existing systems and the gap

2.1 Academic work

Machine learning for network intrusion detection is a mature literature with a well-documented reproducibility problem. Sommer and Paxson's *Outside the Closed World* set out why the field's results so often fail to transfer to deployment: the cost of a false positive, the diversity of benign traffic, and evaluation on corpora whose structure leaks the answer. Arp and colleagues catalogued ten recurring methodological faults in security machine learning, several of which - sampling bias, spurious correlations, inappropriate baselines - we defend against explicitly in Chapter 9.

Work specific to *unidirectional* visibility is thin. The nearest neighbours are flow-exporter studies (what is lost when NetFlow replaces packets) and one-directional sampling work in high-speed backbones. Neither asks our question, which is what a detector should be fed when the reverse direction is structurally unavailable rather than merely sampled away.

2.2 The dataset problem, and what we did about it

CIC-IDS2017 is the most-used benchmark in this area and has documented defects. Engelen, Rimmer and Joosen re-examined the capture and found label errors and feature-extractor faults serious enough to change published conclusions; later work by Lanvin and colleagues reached compatible findings. We therefore use the **corrected re-extraction** published on Zenodo (record 22016274, CC-BY-4.0) rather than the original CSVs, and we make three further decisions that keep the numbers honest:

- **Source and destination IP addresses are excluded from every feature set.** The testbed uses fixed attacker addresses; a model given them memorises the attacker and reports a meaningless near-perfect score. This is the single most consequential preprocessing decision in the pipeline.
- **The split is temporal, never random.** CIC-IDS2017 runs Monday to Friday with different attacks on different days. A random split places flows from one attack episode on both sides of the split and leaks the answer. A temporal split means some attack classes appear only in test - which is realistic, and is why binary F1 is reported as the headline with macro F1 alongside.
- **Every one of the 103 features is classified by observability** into forward-observable (35, kept), backward-derived (33, dropped) and bidirectional aggregate (35, dropped). The classification is printed by the adapter so a reviewer can dispute any single assignment, and invariants over it are pinned by tests.

THE ABLATION TRAP WE AVOIDED

A careless ablation treats `Flow IAT Mean` as "forward IAT with noise" and keeps it. On a one-way tap the sensor computes a different quantity over forward packets only, which this CSV does not contain. We drop such columns rather than assume them observable. Keeping them would have inflated the one-way condition and hidden the very effect we set out to measure.

2.3 Operational tools in use today

Category	Representative tools	Why it does not solve this problem
Signature IDS	Snort, Suricata	Run passively, but a large share of rules match on server responses, and rule updates arrive over a network path the enclave does not have.
Network security monitor	Zeek	Rich protocol logs, but connection-state analysers and certificate inspection assume both directions are present.
Commercial NDR	Darktrace, Vectra, ExtraHop	Cloud analytics, sandboxing and reputation enrichment are outbound by design; licensing is per-IP and recurring; telemetry leaves the enclave.
Diode vendors	Owl Cyber Defense, Waterfall, Fox-IT	They move data across the boundary safely. They do not detect threats inside it - they are the transport this system sits behind.
Published ML pipelines	papers built on CIC-IDS2017	Trained on bidirectional features. 68 of the 103 columns need the reverse direction; we measured the resulting drop at 0.9793 to 0.6903.
Reputation and threat feeds	commercial IP/domain lists	Require a live outbound query. In our generated study, removing the feed <i>improved</i> F1 from 0.926 to 0.971 once behavioural features were present.

Table 4. Operational tools in use today

2.4 The gap, stated precisely

- No public dataset or published pipeline is built for structurally one-way visibility.
- The cost of that visibility had not been quantified, and its cause had not been attributed.
- Deployed detectors rarely decline to answer. Behind a diode, an unverifiable guess carries a cost that a confident wrong label does not pay anywhere else.
- Alert records are rarely provable. If the log can be edited afterwards, an alert is an assertion rather than evidence - which matters for both incident response and the log-retention obligations described in Chapter 16.

CHAPTER 3

Requirements

3.1 Functional requirements

ID	Requirement	Verified by
FR1	Ingest packets or flow records through a read-only interface	tests/test_ingest.py; Ch 4.2
FR2	Discard traffic a one-way tap could not observe, so that training matches deployment	tests/test_visibility.py; Ch 5.1
FR3	Maintain per-host state over a sliding window with bounded memory	tests/test_streaming_host_window.py; Ch 4.4
FR4	Detect each of the six named threat classes	Ch 5.5, exp09
FR5	Emit a severity independent of confidence	tests/test_severity.py; Ch 5.6
FR6	Emit a calibrated confidence, or abstain	exp08; Ch 6
FR7	Seal each alert into a tamper-evident record	tests/test_evidence.py; Ch 7
FR8	Expose alerts through a read-only interface and an offline console	tests/test_api.py; Ch 8.5
FR9	Re-verify evidence independently of the server	Ch 7.4

Table 5. Functional requirements

3.2 Non-functional requirements

ID	Requirement	Target	Measured
NFR1	End-to-end alert latency	bounded and stated	75 s (60 s window + 15 s lateness)
NFR2	Sustained throughput	1 Gbps aspiration	610 to 672 Mbps - not met , stated openly
NFR3	Sensor memory	bounded independent of traffic	2.66 MB for 14,817 hosts
NFR4	Streaming equals batch	no measurable loss	0.98120 vs 0.98119 binary F1
NFR5	Calibration quality	coverage at target	0.908 against 0.90; ECE 0.00084
NFR6	Console operation	no network of any kind	single HTML file, no CDN, no build step
NFR7	Test coverage of claims	every claim has a test	290 tests passing

Table 6. Non-functional requirements

3.3 Constraints and assumptions

- **Constraint.** No component in the detection path may open a network connection. This is enforced by a test that parses every module and fails the build on a network import (Chapter 10.2).
- **Constraint.** Payload bytes must never reach feature code. Protocol features are computed from handshake metadata only.
- **Assumption.** The enclave is physically and administratively access-controlled, which is why the console ships without authentication. Chapter 15 records this as a risk with a mitigation rather than as a settled matter.

- **Assumption.** The diode or SPAN port delivers a faithful copy of the forward direction. Packet loss in the tap itself is outside our control and is not modelled.
- **Assumption.** Clocks within the enclave are consistent to within the 15-second lateness budget. Beyond that, late records are dropped and counted rather than silently reordered.



PART II

Technical design, implementation and evidence

CHAPTER 4

System architecture

4.1 Principles

1. **One-way by construction.** The package layout mirrors the data flow: detect may import from features, never the reverse, and nothing imports the ingest source except the pipeline entry point. The constraint is not a convention - a test enforces it.
2. **Train on what the tap delivers.** A visibility filter sits immediately after ingest, so training data and deployment data pass through the same reduction. This is the difference between a detector that degrades in the field and one that does not.
3. **Single pass, bounded state.** No global sort, no full-corpus pass, no unbounded dictionary. Memory is a function of the number of live hosts, not of traffic volume.
4. **Every output is accountable.** An alert carries what was observed, which model decided, and a cryptographic link to the alert before it.

One-way by construction: no stage may call any stage to its left.

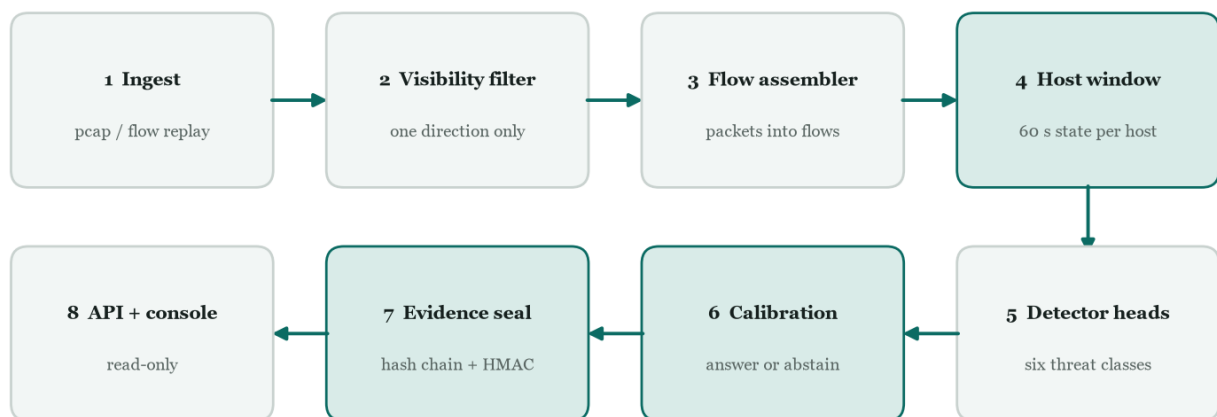


Figure 2. The eight-stage pipeline. Highlighted stages are the three that make one-way detection work: host-window state, calibration, and evidence sealing.

4.2 Stages and responsibilities

Stage	Module	Responsibility	Key design decision
1 Ingest	ingest/pcap.py, ingest/replay.py	Read pcap files, live captures or flow CSVs through one read-only iterator	Adapters at the boundary only; no parser of our own
2 Visibility filter	ingest/visibility.py, ingest/diode.py	Drop everything a one-way tap could not see	Configurable as egress-tap, ingress-tap or off, so the ablation and the deployment share one code path
3 Flow assembler	ingest/flow_assembler.py	Group packets into forward-only flows with idle and active timeouts	15 s idle, 120 s active, matching flow-exporter convention
4 Host window	features/streaming_host_window.py	Sixteen per-host aggregates over a 60 s window	Exact counters promoted to sketches only above 256 distinct values
4b Protocol features	features/protocol.py, ingest/wire.py, ingest/quic.py	DNS name statistics, TLS reassembly, JA4, QUIC Initial parsing	Kept as a separate feature group so earlier results stay comparable
5 Detector heads	detect/heads.py, detect/severity.py	One gradient-boosted head per threat class, plus severity	Decomposition beats one multiclass model for explainability, and each head is independently testable
6 Calibration	calibrate/conformal.py	Per-class conformal thresholds; answer or abstain	Mondrian (class-conditional), because a pooled guarantee is satisfied almost entirely by the dominant class
7 Evidence	evidence/bundle.py	Canonicalise, hash, chain and HMAC every alert	Fixed-precision canonical form, so a float round-trip cannot break a chain
8 API and console	api/server.py, frontend/index.html	Read-only HTTP endpoints, server-sent events, offline console	One HTML file with no framework, no CDN and no build step

Table 7. Stages and responsibilities

4.3 Technology choices and their justification

Layer	Choice	Why this, and not the obvious alternative
Language	Python 3.11+	Library ecosystem and review speed. The throughput ceiling this imposes is measured and reported rather than hidden (Ch 9.4).
Models	XGBoost gradient-boosted trees	Wins on tabular features, trains in seconds, and yields per-feature attribution without a separate explainability stack. A deep model would cost latency and determinism for no measured gain here.
Sequence signals	hand-built timing and size statistics	A recurrent model over packet sequences is future work; the statistics are auditable and cheap, and the PS asks for the evidence, not for a particular architecture.
Calibration	own split-conformal implementation	Small enough to audit line by line, with a distribution-free guarantee. A library would add a dependency for about eighty lines of arithmetic.
Integrity	hashlib SHA-256 + HMAC-SHA256	Standard primitives, no bespoke cryptography. Asymmetric signing is roadmap, not shipped (Ch 7.5).
API	FastAPI with server-sent events	Read-only endpoints and a push stream without WebSocket complexity.
Console	single HTML file, vanilla JS, Web Crypto	Must run with no network and no install. A framework would need a build step and a CDN, both unavailable in an enclave.
Tests	pytest, Playwright	290 backend tests plus three browser engines, because a claim without a test is an opinion.

Table 8. Technology choices and their justification

4.4 Streaming with bounded latency and bounded memory

The window is 60 seconds and the lateness budget is 15 seconds, so an alert appears at most 75 seconds after its window opens. The budget exists because a flow assembler emits records after their flows end, so records arrive out of order with respect to their own start times; several windows are therefore kept open, and anything later than the budget is dropped and counted rather than silently misplaced.

- **Cardinality** (how many distinct peers or ports a host touched) uses HyperLogLog, which estimates distinct counts in fixed space.
- **Frequency** (how concentrated a host's traffic is on its top peer) uses a Count-Min Sketch with Misra-Gries style heavy-hitter tracking.
- **Volume against baseline** uses exponentially decayed per-host counters, so "unusual for this host" needs no stored history.
- **Exactness where it is affordable:** estimators start exact and promote to sketches only above 256 distinct values, which is why 14 of 16 features are bitwise identical to an exact batch computation (exp05).

WHY THIS MATTERS OPERATIONALLY

Bounded memory is what allows the sensor to run on a commodity server in an enclave with no elastic capacity. 2.66 MB of state for 14,817 hosts means state is roughly 0.18 KB per host, so capacity planning is a multiplication rather than a gamble.

CHAPTER 5

Detection methodology

5.1 Visibility profiling: the step most pipelines skip

Before any model is trained, the corpus is passed through the same visibility filter that a deployed sensor would sit behind. Each of CIC-IDS2017's 103 features is classified as forward-observable, backward-derived or bidirectional-aggregate, and only the first class survives. This is what the report calls **visibility-matched training**, and it is the difference between measuring a detector's performance and measuring a dataset's convenience.

5.2 The central finding: memory, not direction

A per-flow detector judges each connection in isolation. On a one-way tap, one connection carries little information. A host's behaviour over a minute carries a great deal, and all of it is visible from one side: how many distinct peers and ports it touched, how regular its inter-arrival times are, how concentrated its traffic is on a single destination, and how its volume compares with its own baseline.

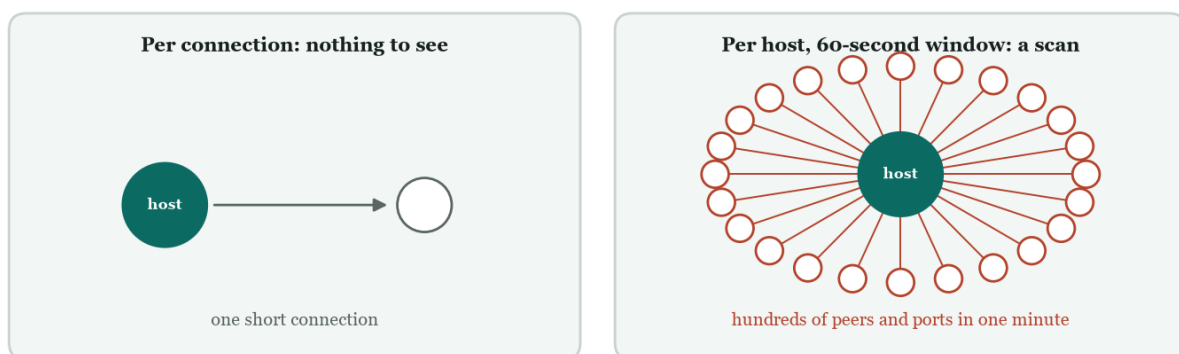


Figure 3. The same traffic seen per connection and per host. Fan-out over a window is visible from one direction; the absent reply is not needed to see it.

5.3 The sixteen host-window features

Feature	Plain meaning	Threat class it serves
hw_src_n_flows, hw_src_n_peers, hw_src_n_dports	how many connections, distinct peers and distinct ports this source used in the window	scanning, worms
hw_src_fanout_per_flow	new peers per connection	scanning
hw_src_peer_concentration	share of traffic to its single top destination	beaconing, exfiltration
hw_src_fwd_pkts, hw_src_fwd_bytes	volume sent	exfiltration, flooding
hw_src_iat_mean, hw_src_iat_cv	mean gap between its connections, and how regular that gap is	command-and-control beaconing
hw_src_bytes_vs_baseline	volume against this host's own decayed baseline	exfiltration
hw_dst_n_flows, hw_dst_n_srcs	connections and distinct senders arriving at one destination	DDoS
hw_dst_src_entropy	dispersion of those senders (spoofed floods are very dispersed)	DDoS, spoofing
hw_dst_fwd_pkts, hw_dst_fwd_bytes, hw_dst_flows_per_src	load arriving at one destination	DDoS, flooding

Table 9. The sixteen host-window features

Five of the ten highest-gain features in the final model come from this group: `hw_dst_flows_per_src`, `hw_src_fanout_per_flow`, `hw_dst_fwd_pkts`, `hw_src_n_dports` and `hw_src_fwd_pkts`. That ranking was a pre-registered prediction, and it held.

5.4 Protocol evidence without decryption

Two of the six threat classes are defined by protocol evidence that host-window aggregates deliberately ignore. Nine further features supply it, kept as a separate group so that every earlier measurement remains comparable:

- **DNS, six features.** Character entropy of queried names, bigram rarity under a causal language model (the n-gram analysis the problem statement names), mean and maximum label length, digit ratio, and query count. Random-looking names indicate a domain-generation algorithm; unusually long labels indicate tunnelling.
- **TLS, three features.** JA4 client fingerprint rarity, whether the fingerprint is novel for this host, and handshake count.

Three findings that only real traffic could produce

Finding, from a 147 MB capture of ordinary browsing	Consequence
94% of real TLS ClientHello messages span multiple TCP segments. 91 of 97 failed to parse before reassembly existed.	TCP reassembly for the handshake is mandatory, not an optimisation.
JA3 produced 92 distinct fingerprints where JA4 produced 7 over the same 97 handshakes, because Chrome randomises extension order.	JA3 cannot be used as a rarity signal on modern browsers. The problem statement permits either; only one of them works.
UDP/443 outnumbered TCP/443 by 80,291 to 32,069 packets. Most HTTPS is now QUIC.	We first called QUIC a hard ceiling. We were wrong: QUIC Initial packets are decryptable with published keys (RFC 9001), which reaches the handshake without touching payload. 1-RTT keys remain out of reach, and that limit stands.

Table 10. Protocol evidence without decryption

5.5 The six detector heads

Head	Threat class	Highest-gain feature learned	Average precision	Support
volumetric	Volumetric / protocol DDoS	hw_dst_fwd_bytes	1.000	99,216
dga	DGA and DNS tunnelling	hw_src_qname_bigram_rarity	0.981	53
encrypted	Malware in encrypted sessions	hw_src_tls_count	0.924	365
beacon	C2 beaconing	hw_src_iat_mean	0.908	1,258
scan	Reconnaissance and scanning	hw_src_n_peers	0.756	331
exfil	Data exfiltration	hw_src_fwd_bytes	0.735	13

Table 11. The six detector heads

READ THE SUPPORT COLUMN

The exfiltration head is evaluated on thirteen test cells and the DGA head on fifty-three. Those numbers are thin enough that the corresponding scores should be read as indicative, not as performance guarantees. We report them with their support rather than quoting the score alone.

5.6 Severity, kept separate from confidence

The obvious formula, severity = class x confidence, destroys both inputs: a near-certain port scan and a doubtful exfiltration multiply to similar numbers and demand opposite responses. CVSS separates base score from confidence and NIST SP 800-30 separates impact from likelihood; so does this system. The severity function does not accept a confidence argument, and a test asserts its signature so that nobody can quietly add one.

THE FIRST VERSION OF SEVERITY WAS WRONG, AND THE CORPUS SAID SO

Each class was originally given its own magnitude feature - ports for scanning, flows for beaconing. Measured across 90,794 logged alerts the medians came out at 0.00, because an alert fires on a host and the evidence may sit on either side of that host's cell: a scan alert fires on the host being scanned, whose source-side counters are empty by construction. Half the magnitude features were reading the wrong side and filing established beacons as low severity. The fix was to narrow the claim rather than to find a cleverer feature: volume raises severity only where volume is the damage (exfiltration, covert encrypted channels), read side-agnostically. A magnitude that reads the wrong side is worse than no magnitude, because it looks quantitative.

CHAPTER 6

Uncertainty, calibration and abstention

6.1 Why a diode sensor must be able to decline

A detector behind a one-way link cannot ask a follow-up question. It cannot fetch the certificate, probe the port or consult a feed. When the evidence is genuinely ambiguous the only honest options are to guess or to say so. Forcing a label manufactures confidence the sensor does not have, and the analyst has no way to tell the difference between a confident correct answer and a confident invention.

6.2 Split-conformal prediction

A calibration set that the model never trained on provides nonconformity scores; the $(1 - \alpha)$ quantile of those scores becomes the threshold. The guarantee is distribution-free and finite-sample: over exchangeable data the prediction set contains the true label at least $(1 - \alpha)$ of the time, with no assumption that the model is well specified. ABSTAIN is emitted when no label clears its threshold, and it means precisely: *under this sensor's visibility, the observation does not support a confident label*.

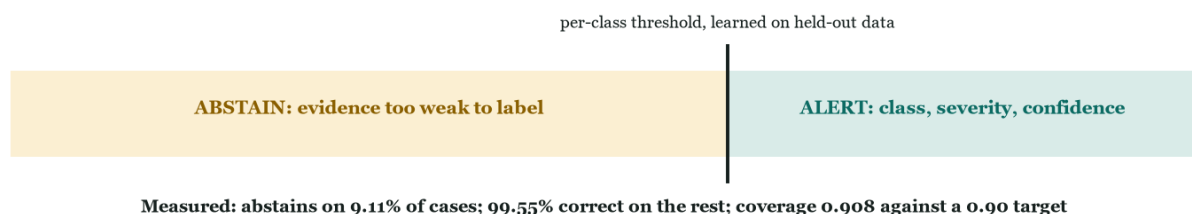


Figure 4. Abstention as a calibrated decision. The threshold is learned from held-out data, per class, and is not hand-tuned.

6.3 Why Mondrian, and a failure along the way

A pooled conformal guarantee is satisfied almost entirely by the dominant class: at $\alpha = 0.10$ the average coverage looks correct while the rare attack classes are quietly uncovered. Mondrian (class-conditional) conformal calibrates a separate threshold per class and fixes that. Our first Mondrian implementation abstained on 100% of everything - a calibration bug that a coverage plot made obvious immediately, and a reason the console exposes the calibration panel rather than a single accuracy number.

Measure	Value	Interpretation
Empirical coverage	0.908	true label inside the prediction set 90.8% of the time, against a 0.90 target
Abstention rate	9.11%	how often the sensor declines to label
Accuracy on answered cases	99.55%	how often it is right when it does answer
Expected calibration error	0.00084	stated confidence tracks observed accuracy almost exactly

Table 12. Why Mondrian, and a failure along the way

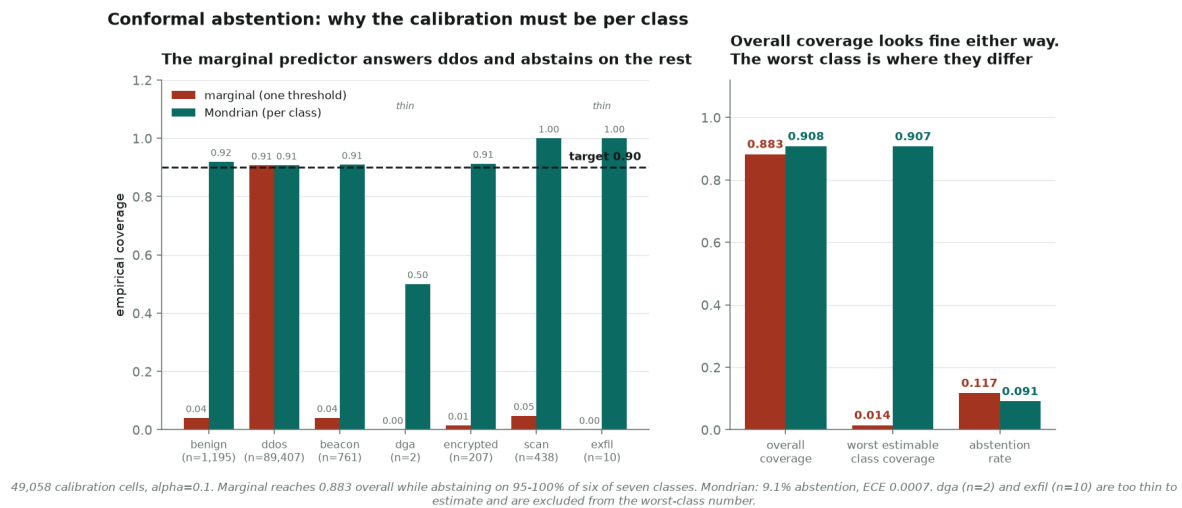


Figure 5. Conformal calibration measured on real traffic: per-class coverage against target, and the abstention rate that buys it.

6.4 What abstention means for the operator

- Abstentions are **logged, not discarded**. They appear in the console as a distinct state, and they are counted in the header statistics.
- A rising abstention rate is a **drift signal**: it is the sensor reporting that traffic no longer resembles its calibration set, which is exactly the condition a diode deployment cannot otherwise detect.
- An operator can tune α to trade coverage for volume, and the trade is explicit rather than buried in a threshold.

CHAPTER 7

Evidence, integrity and the threat model

7.1 What an alert has to prove

An alert is only useful in an investigation if nobody could have altered it afterwards - including the operator of the sensor. Each alert is stored as a **bundle**: the observed feature vector, the fingerprint of the model that decided, the decision path, the calibrated confidence, the severity, and the hash of the previous bundle.

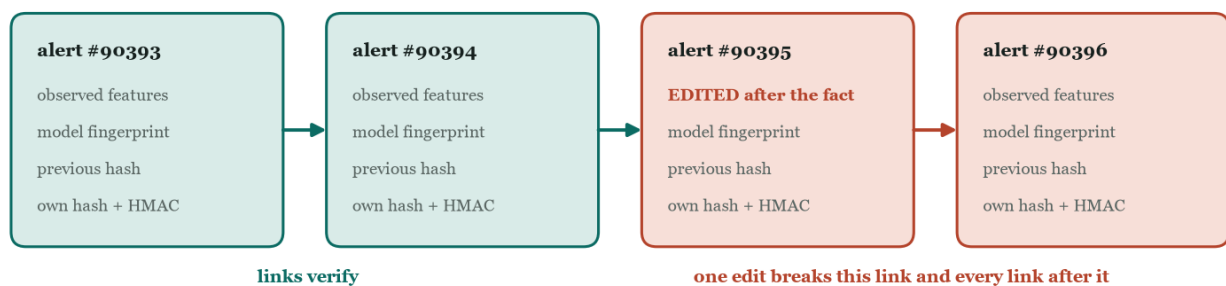


Figure 6. The hash chain. Editing one stored alert breaks its own seal and every link after it, which is what the console displays.

7.2 Canonicalisation: the part that is easy to get wrong

Hashing a record means hashing bytes, and the same logical record can serialise to different bytes. Four decisions make the digest stable, each pinned by a test:

- **Key order is normalised**, so a dictionary that round-trips through JSON in a different order still hashes identically.
- **Floating-point values are written at fixed precision**, so a value that survives a save and reload does not silently change its digest.
- **Negative zero hashes like zero**, because IEEE 754 distinguishes them and arithmetic can produce either.
- **Non-finite values are rejected rather than encoded**, so a NaN cannot enter the digest and make a chain unverifiable.

7.3 Threat model

Adversary capability	Result	Mechanism
Edit a field in one stored alert	Detected, at that entry	the entry's own hash no longer matches
Delete an entry	Detected	the successor's previous-hash link dangles
Reorder entries	Detected	chain order is part of the digest
Swap one alert's feature vector for another's	Detected	the feature vector is inside the hashed canonical form
Recompute every hash forward after an edit	Detected	each bundle also carries HMAC-SHA256 under a key held in the enclave, which a re-forge cannot reproduce
Tamper, then save and reload the log	Detected	canonical form is stable across the round trip
Tamper through the API	Detected	the API is read-only and verification re-derives from stored bytes
Steal the HMAC key	Not detected	a forged chain becomes indistinguishable. Mitigation is hardware key custody and external anchoring - roadmap, not shipped

Table 13. Threat model

7.4 Independent verification in the browser

The console does not ask the server whether the log is intact. It re-computes every SHA-256 digest itself using the Web Crypto API and re-links the chain in the browser. The server's own verdict is displayed beside the browser's. When the two disagree, that disagreement is the alarm - a property no single-implementation check can offer, and the reason the demonstration shows the two verdicts side by side.

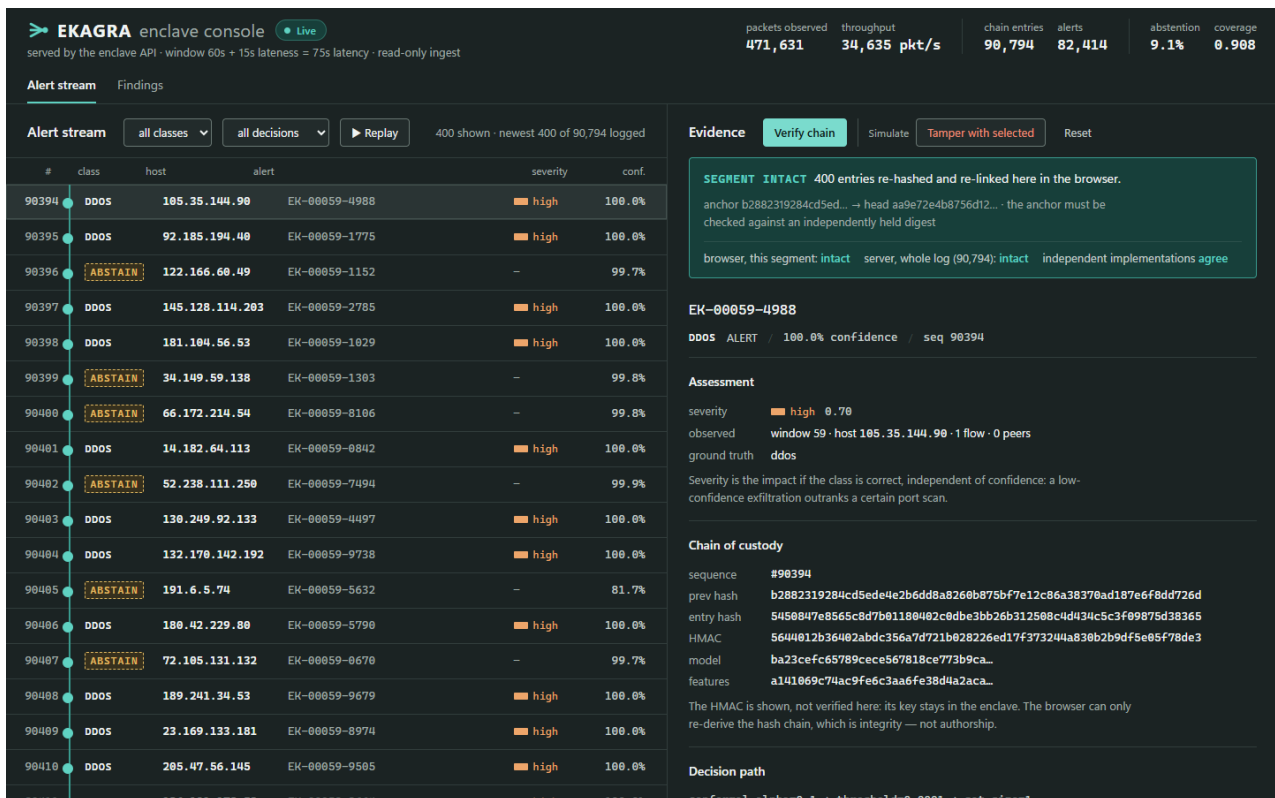


Figure 7. Chain verified: 400 entries re-hashed inside the browser, every link intact.

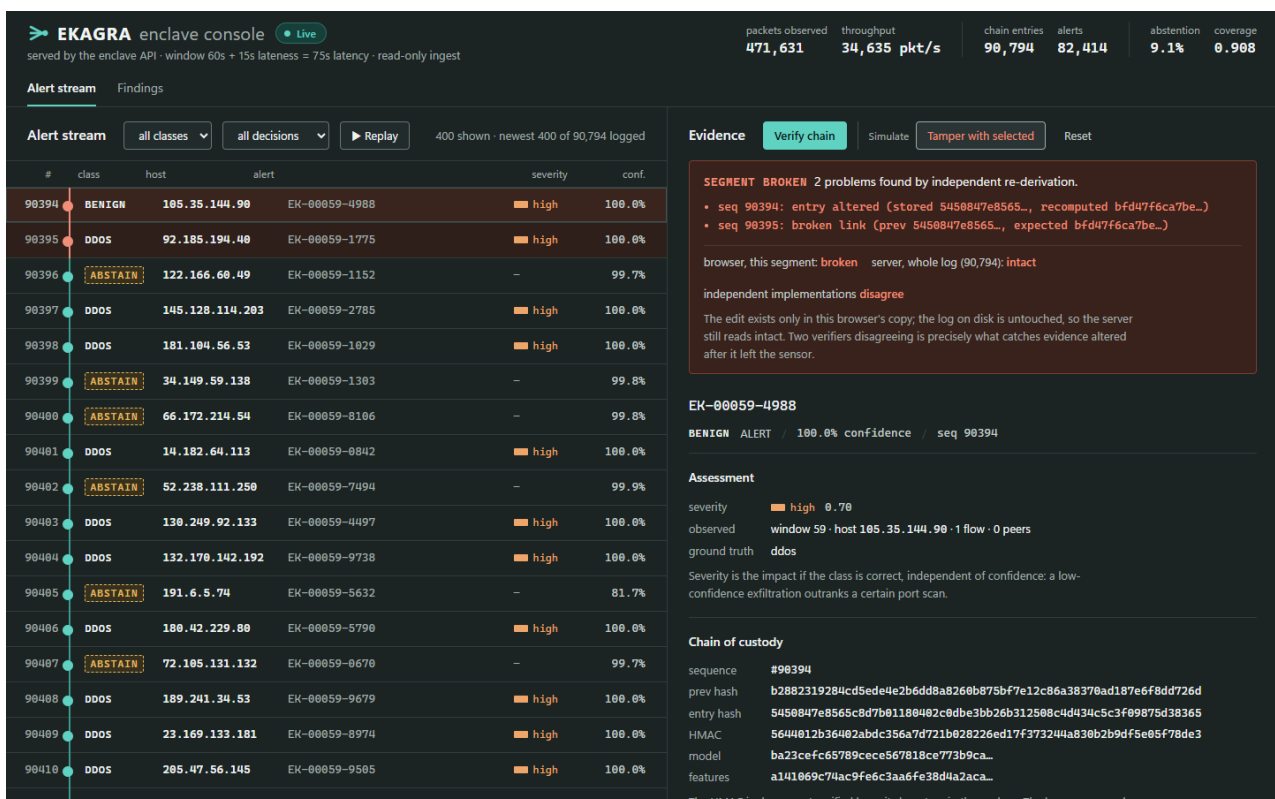


Figure 8. After one stored alert is edited: the break is located at the exact rows, and the two independent verifiers disagree.

7.5 The limit, stated

WHAT THIS DOES NOT SURVIVE

Integrity rests on a key held inside the enclave. An adversary who steals that key can rebuild a valid chain, and nothing in the current design would reveal it. There is no external anchor and no asymmetric signature yet. Chapter 19 places hardware key custody and public-key signing at priority four, and Chapter 15 carries the corresponding risk.

CHAPTER 8

Implementation

8.1 Repository layout

```
ekagra/backend/src/ekagra/
  ingest/      pcap, replay, wire (DNS/TLS), quic, diode, visibility,
               flow_assembler, synthetic, diffuse, records
  features/    streaming_host_window, host_window, protocol, sketches,
               extractors
  detect/      heads, severity, base
  calibrate/   conformal
  evidence/    bundle
  pipeline/    sharded
  api/         server
ekagra/backend/experiments/  exp01 .. exp11, make_figures*
ekagra/backend/tests/        290 tests
ekagra/frontend/index.html   the whole console, one file
```

8.2 Scale of the implementation

63

Python modules

14,253

lines of code

290

automated tests

10

pre-registered experiments

8.3 Algorithms worth naming

Algorithm	Where	Why it is needed
HyperLogLog	distinct peers, ports and sources per host	exact distinct counts need a dictionary per host, which is unbounded memory at line rate
Count-Min Sketch	per-host frequency and peer concentration	heavy hitters in fixed space, with a bounded and stated error
Exponentially decayed counters	volume against a host's own baseline	"unusual for this host" without storing history
Causal bigram model	DNS name rarity	catches generated names that character entropy alone misses; earns its keep only with sufficient history (exp11)
Split-conformal, Mondrian	confidence and abstention	distribution-free coverage guarantee, per class
Gradient-boosted trees	six detector heads	best-performing and directly interpretable on tabular features
SHA-256 chain + HMAC-SHA256	evidence	tamper evidence that survives a forward re-forge

Table 14. Algorithms worth naming

8.4 Sharding, and an honest result

Traffic is partitioned by host across worker processes so that per-host state stays local to one shard. Throughput scales sub-linearly: 35,992 packets per second on one shard, 108,938 on twelve, a speed-up of 3.03. Four pre-registered predictions about sharding were refuted in a single experiment, including our expectation that the sharded output would be bit-identical to the single-process output: 8 to 21 cells per configuration disagree, because a host's records can straddle a window boundary differently once partitioned.

8.5 The read-only API and the console

Endpoint	Method	Returns
/	GET	the console (single HTML file)
/data.js	GET	the bundled snapshot, so the console works with no server
/alerts	GET	alert bundles, filterable by class and decision
/events	GET	server-sent event stream of new alerts
/chain/verify	GET	the server's own verification verdict
/stats	GET	counters shown in the console header

Table 15. The read-only API and the console There is no write endpoint anywhere in the surface, and a test fails the build if one appears.

The console is a single HTML file with no framework, no CDN reference and no build step, because an enclave has no package registry and no internet. Opened directly from disk with no server at all, it falls back to a bundled snapshot so that a reviewer can inspect the evidence model without running anything.

CHAPTER 9

Experimental programme and results

9.1 Method: pre-registration

Before an experiment's first run, its predictions are written into the experiment file. The run prints a verdict for each and persists it to `results/exp*_verdicts.json`. Predictions are never edited afterwards; where a prediction was badly worded, it is annotated rather than reworded. This removes the most common way results mislead, which is deciding what you expected after seeing the answer.

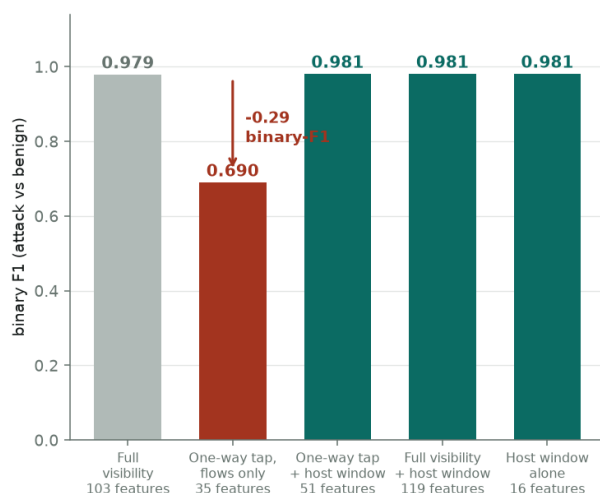
Experiment	Question it asks	Predictions	Refuted
exp01	Does reduced visibility hurt? (generated traffic)	4	4
exp03	The same question on real traffic	3	1
exp04	How much of the gap is real, with controls?	3	0
exp05	Does streaming match exact batch computation?	4	0
exp06	Does the full packet pipeline hold up end to end?	4	1
exp07	Does sharding reach line rate?	5	4
exp08	Evidence chain and console behaviour	3	0
exp09	Do six separate heads beat one multiclass model?	4	2
exp10	What happens when attacks are slow and diffuse?	6	2
exp11	Does DGA detection work against real benign names?	6	3
Total		42	17

Table 16. Method: pre-registration

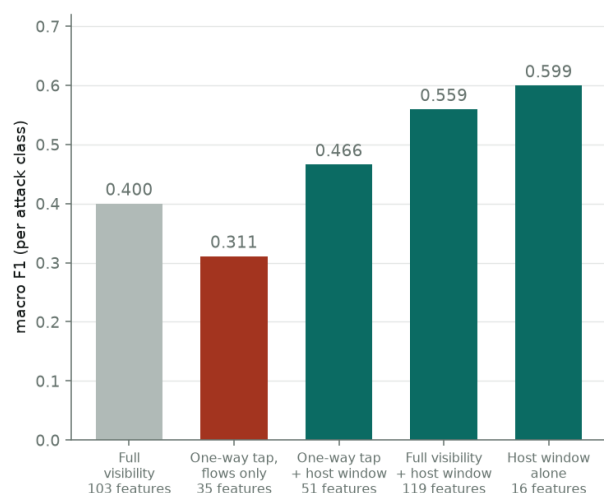
9.2 The headline measurement

CIC-IDS2017: what a one-way tap actually costs

Losing the reverse direction costs nothing — provided the sensor keeps host state



On multi-class the host window is not a patch, it is the signal



877,801 flows, 60s windows. 16 host-window features alone (0.599 macro-F1) beat all 103 full-visibility features (0.400).

Figure 9. 877,801 real flows, temporal split, addresses excluded. Left: attack-versus-benign. Right: per-class. The red bar is a conventional detector behind the tap.

Condition	Features	Binary F1	Macro F1	What it establishes
A - full two-way visibility	103	0.9793	0.3999	the reference point
C - one-way tap, per-flow features only	35	0.6903	0.3110	the cost of naive deployment
E - EKAGRA sensor (one-way + host window)	51	0.9810	0.4660	the cost is recoverable
G - host window alone (our control)	16	0.9812	0.5995	and per-host state is what recovers it

Table 17. The headline measurement

OUR OWN CONTROL NARROWED OUR HEADLINE CLAIM

This project was originally built around a claim that a purpose-designed one-way feature set beats a retrained baseline. Condition G - sixteen host-window features and nothing else - matched the full model at 0.9812, which showed that per-host state, not our feature engineering, was doing the work. We rewrote the claim and published the control. Predictions P2, P3 and P4 are recorded as refuted in Chapter 9.7.

9.3 The stress test that narrowed it further

Real intrusions are often slow and originate from hosts that also carry ordinary traffic. Experiment 10 re-times and re-homes the same real attack flows so that they share each host-window cell with 59 to 188 times as many benign flows, leaving every per-flow feature untouched.

Low-rate, diffuse attacks: the caveat on experiment 04, tested

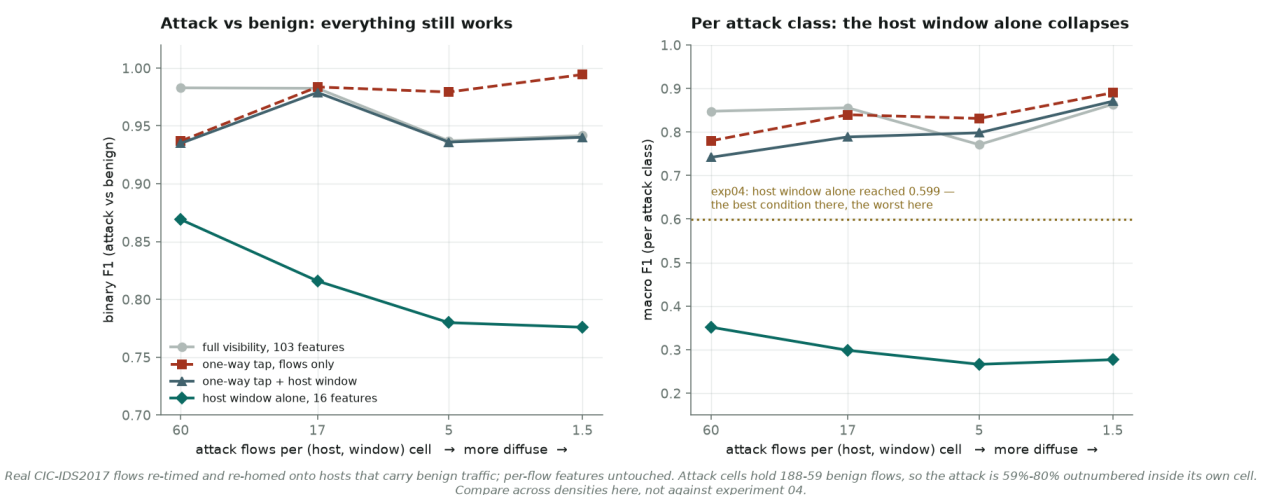


Figure 10. As attacks become more diffuse, one-way per-flow features track full visibility, while host-window features alone collapse on a per-class basis.

- **The one-way tap still costs nothing:** forward-only features track or beat full visibility at every density tested (0.937 to 0.994 binary F1).
- **Host-window features alone fail.** Every flow in a cell receives the same vector, so an attack outnumbered 59-to-1 inside its own cell cannot be separated from its neighbours. The condition that was best in exp04 (0.599 macro F1) is worst here (0.35 falling to 0.28).

- **The shipped configuration keeps both**, which is why condition E and not condition G is what the sensor runs.

9.4 Performance

Property	Measured	Note
Flow-level throughput	171,501 flows/s	feature path only
Packet pipeline, one shard	35,992 packets/s	full parse and assembly
Packet pipeline, twelve shards	108,938 packets/s	speed-up 3.03
Required for 1 Gbps at 700-byte packets	178,571 packets/s	not reached ; 610 to 672 Mbps measured
End-to-end latency	75 s	60 s window + 15 s lateness budget
Sensor state	2.66 MB for 14,817 hosts	about 0.18 KB per host
Streaming vs exact batch	0.98120 vs 0.98119 binary F1	14 of 16 features bitwise identical

Table 18. Performance

A CLAIM WE RETRACTED

An earlier version of this work claimed 1 Gbps line rate. Measurement did not support it and the claim was withdrawn; the honest figure is 610 to 672 Mbps, and our own documents once disagreed with each other about it (108,938 pkt/s in one file, 119,918 in another - throughput benchmarks move with machine load). A compiled fast path is the route to line rate and is on the roadmap, not in the measurements.

9.5 Domain-generation algorithms: the weakest class

DGA family (construction)	Combined AUC	Reading
uniform random letters	0.9787	easy: character statistics separate cleanly
necurs	0.9434	strong
conficker	0.9402	strong
matsnu (dictionary words)	0.8941	harder than random, better than expected
banjori (mutates four letters of a real domain)	0.7475	weak
suppobox (two dictionary words)	0.6949	weak: it looks like a real name

Table 19. Domain-generation algorithms: the weakest class Measured against 279 real benign registrable names taken from our own capture, not against generated benign names.

THE MOST IMPORTANT NEGATIVE RESULT IN THIS PROJECT

A detection threshold calibrated on our own *generated* benign names flags **89.6%** of *real* benign names. Generated traffic is a controlled instrument for isolating an effect; it is not a substitute for real data, and any threshold set on it is meaningless in deployment. This single number is why every operating point in this report is set on real traffic.

9.6 Every refuted prediction

ID	Prediction, as written before the run	Outcome
P1	A two-way detector collapses at every reduced-visibility rung	Partly: it collapses at the one-way rungs only
P2	Visibility-matched retraining recovers materially but not fully	It recovered fully
P3	Our unidirectional-native feature set beats simple retraining	It did not. The original headline claim was wrong
P4	Losing threat-intelligence enrichment is the single largest drop	It cost nothing; F1 improved from 0.926 to 0.971
S2	On real data, flow features close most of the gap (within 0.10 macro F1)	The gap stayed at 0.156, which is what led us to host-window state
V4	More than 100,000 packets/s single-threaded	35,992 packets/s
W1	Sharded output is identical to single-process output	8 to 21 cells differ per configuration
W3	Four shards exceed 100,000 packets/s	77,795 packets/s
W4	Eight shards reach 1 Gbps (178,571 packets/s)	Not reached; best 108,938 on twelve shards
W5	Scaling efficiency above 0.6 at four shards	0.54
Y1	More than 1% of attack cells carry two or more classes	0.08%
Y3	The two handicapped heads score clearly below the other four	They did not: AP 0.981 (dga) and 0.924 (encrypted)
Z2	Host-window-alone loses at least 0.15 binary F1 on diffuse attacks	It lost 0.093 binary F1; the collapse was in macro F1 instead
Z4	The cost of the one-way tap grows as attacks become diffuse	It shrank: one-way features did better at low density
D2	Dictionary DGA families stay below 0.75 AUC	matsnu reached 0.894; supobox stayed at 0.695
D4	At a 1% false-positive rate, catch 90% of uniform-random DGA	Caught 66.2%
D6	A threshold calibrated on generated benign names transfers to real ones	It flagged 89.6% of real benign names

Table 20. Every refuted prediction

CHAPTER 10

Verification, testing and quality

10.1 Test strategy

Layer	What is tested	Examples
Unit	parsers, sketches, feature arithmetic	DNS pointer-loop limits, HyperLogLog error bounds, negative-zero hashing
Property	invariants that must hold for any input	canonical form is order-independent and precision-stable
Constraint	architectural rules	no network import in the detection path; no write endpoint in the API
Adversarial	integrity under attack	seven tamper tests including a full forward re-forge without the key
Integration	the pipeline end to end	pcap in, sealed alerts out
Interface	the console in real browsers	Chromium, Firefox and WebKit, live and offline, plus mobile emulation

Table 21. Test strategy

10.2 Constraints enforced by the build

Four of this system's guarantees are architectural, and architectural guarantees decay unless something mechanical defends them:

- A test walks the abstract syntax tree of every module in the detection path and fails the build if any network client is imported - `socket`, `requests`, `urllib`, `httpx`, `aiohttp` and others. This is what makes "read-only" a property rather than a promise.
- A test fails the build if any write endpoint appears in the API surface.
- A test asserts that the severity function's signature does not accept confidence.
- A test checks that every value interpolated into the console's DOM is escaped, so an attacker-controlled hostname cannot become script.

10.3 Results

290 tests passing	0 known defects open	7 integrity attacks tested	3 browser engines verified
-----------------------------	--------------------------------	--------------------------------------	--------------------------------------

Hostile-input testing covers the parsers most exposed to attacker-controlled bytes: DNS name compression with pointer loops, truncated TLS records, and QUIC Initial packets with inconsistent length fields. The parsers reject rather than crash, which matters because in this deployment a crash is the only kind of denial of service an attacker can still cause.



PART III

The business case

CHAPTER 11

Market and opportunity

11.1 Who is obliged to solve this problem

The buyer for this system is not a generic enterprise security team. It is an operator of infrastructure that the state has designated as critical, and whose monitoring is already constrained by a one-way boundary.

India's **National Critical Information Infrastructure Protection Centre (NCIIPC)** is a unit of NTRO - the same organisation that issued this problem statement - created under Section 70A of the Information Technology Act, 2000 (as amended in 2008) and notified in January 2014. It is the national nodal agency for protecting critical information infrastructure, and it identifies these critical sectors:

NCIIPC critical sector	Why one-way monitoring appears there
Power and energy	Grid and plant control networks are segmented from IT networks; diodes are a standard means of exporting telemetry without exposing control
Banking, financial services and insurance	Card and settlement environments run isolated zones with tightly controlled egress
Telecom	Core signalling networks separated from management planes
Transport	Rail signalling and airport operations technology, isolated by design
Government	Classified and restricted networks where no inbound path may exist
Strategic and public enterprises	Defence production and space, the original diode constituency
Health	Hospital operational technology, an emerging segment

Table 22. Who is obliged to solve this problem

11.2 The problem is growing, and it is measured

CERT-In handled **29.44 lakh** cyber security incidents in 2025, an increase of about 85% over the 15.92 lakh recorded in 2023, alongside 1,530 alerts and 390 vulnerability notes; 231 audit organisations were empanelled to expand assessment capacity across critical ICT infrastructure. Incident volume of that order is what makes an analyst's time the scarce resource, and it is the reason this system treats a calibrated abstention as more valuable than an extra uncertain alert.

11.3 Market size

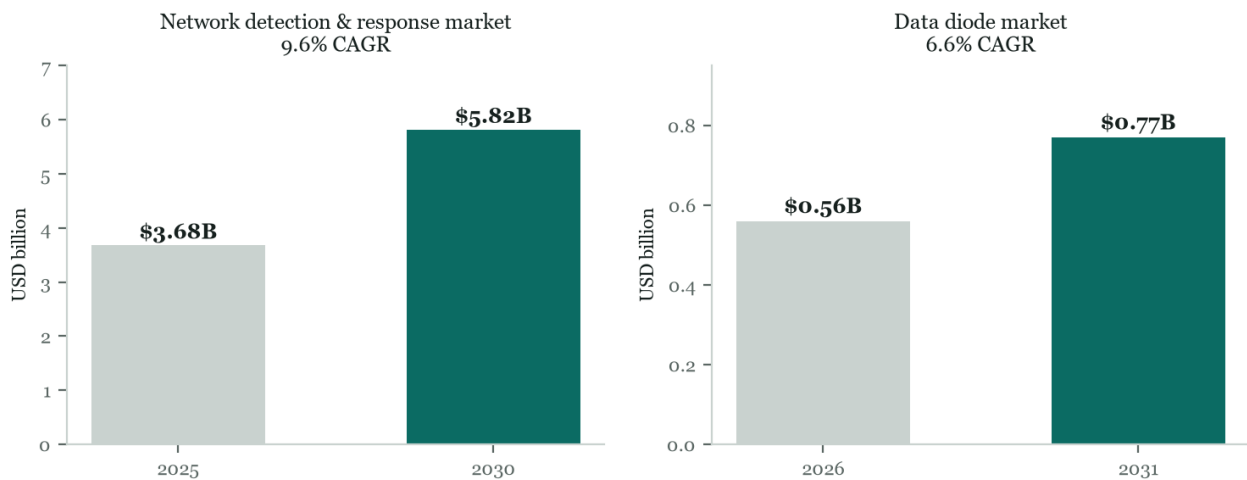


Figure 11. Two adjacent markets. Network detection and response is the capability market; the data diode market is a proxy for the number of deployments where that capability must work with no return path. Source: MarketsandMarkets.

Layer	Definition used here	Basis
TAM	Global network detection and response: \$3.68B in 2025 growing to \$5.82B by 2030 at 9.6% CAGR	MarketsandMarkets, published figures
SAM	Deployments behind a one-way boundary, proxied by the data diode market: \$0.56B in 2026 growing to \$0.77B by 2031 at 6.6% CAGR	MarketsandMarkets; the diode is the hardware whose presence defines our addressable case
SOM (initial)	Indian critical-infrastructure operators across NCIIPC's sectors, entered through government pilots rather than open-market sales	Our own judgement, stated as judgement, not as a forecast

Table 23. Market size

AN HONEST NOTE ON MARKET NUMBERS

Research firms disagree materially about the diode market: against MarketsandMarkets' \$0.56B for 2026, other published estimates for adjacent definitions range from about \$1.2B to \$1.8B, with CAGRs from 6.6% to 15%. The spread comes from scope - whether gateways, services and software are counted. We quote one source consistently and name it, rather than selecting the largest number available.

11.4 Why now

- **Encrypted traffic has outgrown inspection.** In our own capture, QUIC carried more HTTPS packets than TCP. Detection that depends on payload inspection is losing ground; metadata-based detection is the remaining lever.
- **Regulatory pressure is rising.** CERT-In's 2022 directions oblige a wide class of organisations to maintain logs securely for 180 days (Chapter 16), which raises the value of evidence that can be shown to be unaltered.
- **Strategic autonomy is procurement policy, not sentiment.** A detector that runs with no foreign cloud dependency and no outbound telemetry is easier to approve for a classified network than one that phones home.

CHAPTER 12

Competitive landscape and positioning

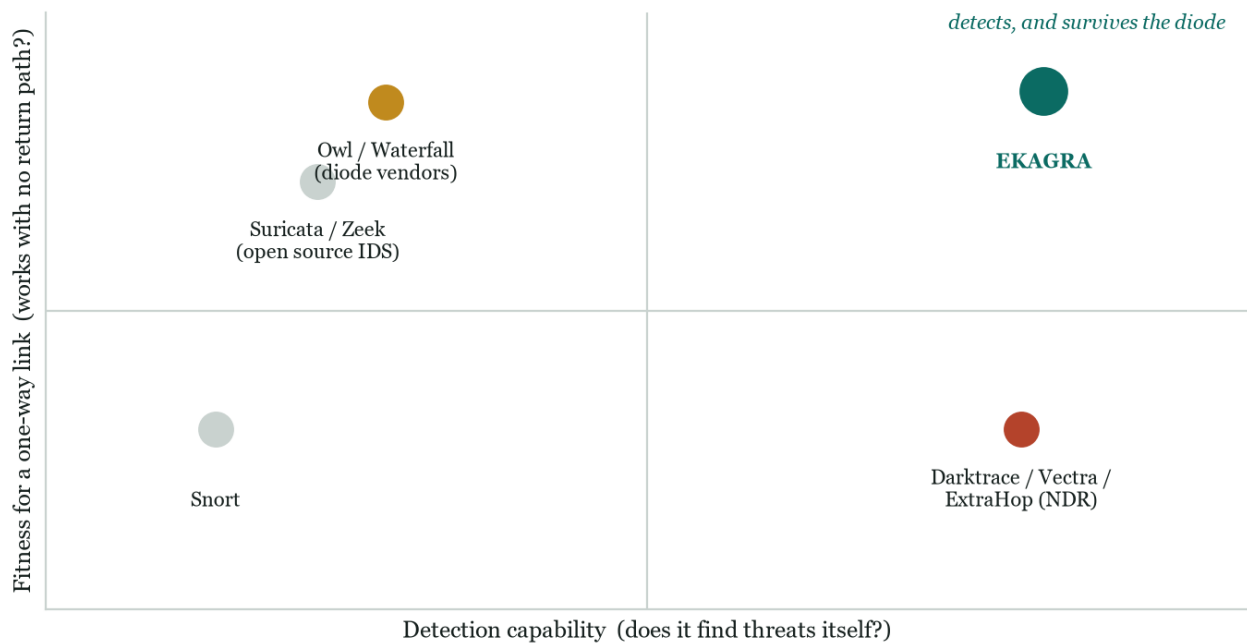


Figure 12. The two axes that matter for this buyer: can the product detect threats itself, and does it work when there is no return path? The upper-right quadrant is where a diode enclave needs a product to sit.

12.1 Feature comparison

Capability	Suricata / Zeek	Commercial NDR	Diode vendors	EKAGRA
Works with no return path	Partly	No	N/A (transport)	Yes, by design
Detects threats itself	Yes (signatures)	Yes	No	Yes (six classes)
Needs outbound updates or cloud	Rule feeds	Yes	No	No
Trained on one-way visibility	No	No	N/A	Yes
Declines to answer when unsure	No	Rarely	N/A	Yes, calibrated
Tamper-evident alert records	No	Varies	N/A	Yes, verifiable offline
Licence cost	Zero	Per IP, recurring	Hardware capex	Zero
Data leaves the enclave	No	Usually	No	No

Table 24. Feature comparison

12.2 What is defensible, and what is not

Asset	How defensible	Assessment
The measurement itself (what one-way visibility costs, and why)	Publishable, reproducible, cited	Not exclusive - but being first and public is a credibility asset, not a moat
Visibility-matched training procedure	Method, transferable to any sensor placement	Moderate: easy to copy once described, which is why we describe it
Calibrated abstention tuned for this deployment	Engineering plus operating experience	Moderate
Evidence chain with independent browser verification	Engineering and design	Moderate; the design choice to verify twice is unusual in this category
The pre-registered experimental record	Reputation	Strongest asset: an evaluator can check our failures, which very few submissions in this space can offer

Table 25. What is defensible, and what is not

POSITIONING IN ONE SENTENCE

Diode vendors move data across the boundary safely and commercial NDR detects threats where a return path exists; EKAGRA is the detection layer for the enclave on the far side of the diode, which is precisely where neither of them operates.

CHAPTER 13

Business model, pricing and cost

13.1 Model: open core with paid assurance

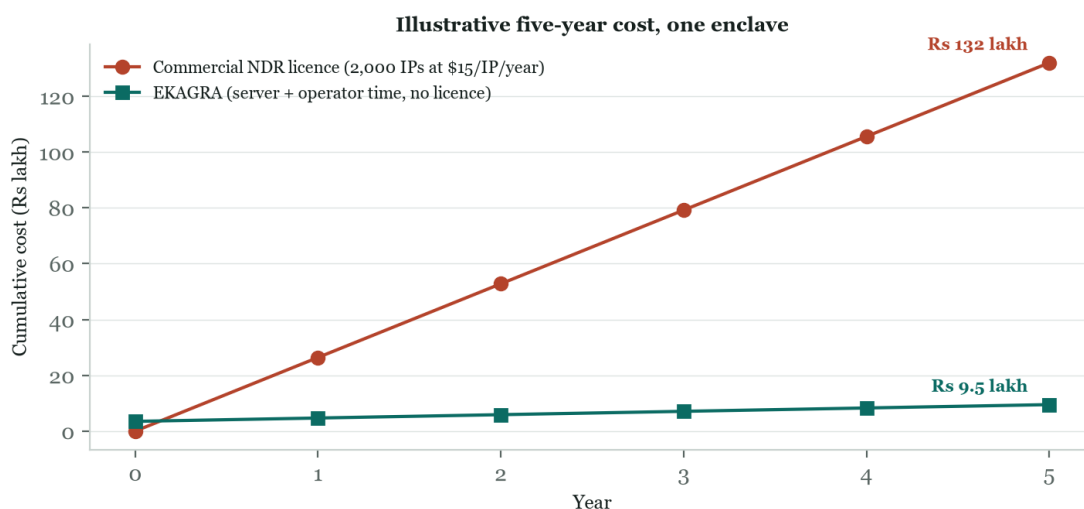
The detection engine, the console and the evidence format are open and free, for three reasons that are specific to this buyer rather than ideological. A classified network cannot accept a component it is not allowed to inspect. A security claim that cannot be audited is worth less than one that can. And a zero-licence engine removes the recurring foreign-currency line item that makes commercial NDR hard to sustain across many small enclaves.

Offering	What the customer gets	Commercial basis
Core engine	Sensor, console, evidence format, experiments	Free and open; no per-IP or per-site fee
Deployment and calibration	Visibility profiling for the site's own traffic, threshold calibration on local data, operator training	Fixed-fee engagement per enclave
Support and assurance	Updates, incident assistance, verification of archived evidence	Annual subscription per site
Integration	Export into an existing SOC workflow or SIEM, custom heads for a sector's own threats	Project fee
Certification support	Documentation and evidence packages for evaluation and empanelment	Project fee

Table 26. Model: open core with paid assurance

The margin sits in calibration and assurance, which is also where the customer's real risk sits: Chapter 9 shows that a threshold set on the wrong corpus flags 89.6% of benign names. Calibration is not a service invented to create revenue; it is the step that determines whether the system works at that site.

13.2 Cost of ownership



Assumptions, stated so they can be challenged: 2,000 monitored IPs; list price \$15 per IP per year at Rs 88/USD; one commodity server at Rs 3.5 lakh; Rs 1.2 lakh a year of operator time. No discount negotiation is modelled.

Figure 13. Five-year cumulative cost for one enclave under the stated assumptions. The assumptions are printed on the figure so that a reviewer can replace them.

Cost line	EKAGRA	Commercial NDR (list price)
Software licence	Zero	About Rs 26 lakh a year at 2,000 IPs and \$15 per IP
Hardware	One commodity server, about Rs 3.5 lakh, no GPU	Appliance or cloud, varies
Operator time	About Rs 1.2 lakh a year	Comparable
Data egress	None: nothing leaves the enclave	Cloud analytics traffic
Five-year total	About Rs 9.5 lakh	About Rs 132 lakh

Table 27. Cost of ownership Assumptions: 2,000 monitored IPs, list price of \$15 per IP per year at Rs 88 to the dollar, no negotiated discount, one server amortised over the period. Real enterprise discounts are substantial and would narrow this gap; the ratio, not the absolute figure, is the point.

13.3 Unit economics of an enclave

- One sensor covers one enclave. Capacity is bounded by throughput (610 to 672 Mbps today) and by host count (about 0.18 KB of state per host), so sizing is arithmetic, not guesswork.
- A site beyond that throughput adds shards or servers; cost grows in steps of a commodity server rather than in steps of a licence tier.
- Because there is no per-IP meter, monitoring more of the network does not increase the bill - which is the behaviour a defender wants and a per-IP licence discourages.

CHAPTER 14

Go-to-market and deployment

14.1 Where the system physically sits

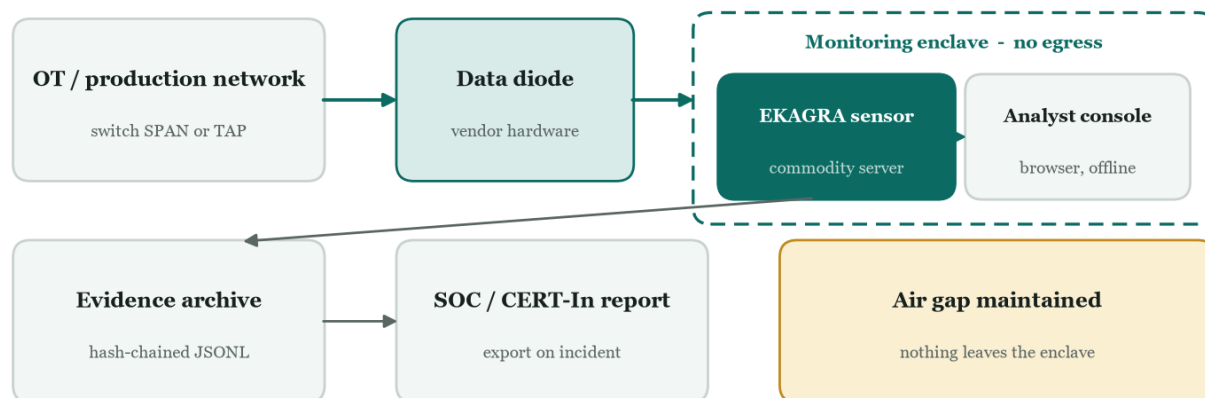


Figure 14. Deployment topology. The sensor and console live entirely inside the monitoring enclave; evidence is archived there and exported only as part of a deliberate incident report.

14.2 Adoption path

Phase	Activity	Evidence that the phase succeeded
0. Hackathon	Working sensor, reproducible experiments, published refutations	This report and the repository
1. Pilot	One enclave with a friendly operator; profile the site's own visibility, calibrate on its traffic, run beside the incumbent tool for a quarter	Abstention rate and false-positive load measured on live traffic
2. Hardening	Key custody in hardware, packet-size and timing features, compiled fast path	Line rate reached; integrity survives key theft
3. Evaluation	Independent security evaluation and documentation for empanelment	Third-party evaluation report
4. Procurement	Listing through government procurement channels; support contracts with operators	First paid assurance contract
5. Sector spread	Sector-specific heads (grid protocols, rail signalling) built on the same core	Second sector deployed without forking the engine

Table 28. Adoption path

14.3 Route to the customer

- **Through the problem owner.** NTRO issued the problem statement and NCIIPC is its unit; a pilot sponsored by the problem owner is the natural first deployment and needs no market creation.
- **Through sector regulators and CERT-In empanelment,** where audit and assessment organisations already engage the same operators.

- **Through public-sector enterprises** in power and transport, whose operational technology networks already contain diodes purchased for compliance reasons.
- **Through academic collaboration**, because the measurement is publishable and a published result is a procurement asset in this sector.

14.4 What would make a pilot fail, and how we would know early

Failure mode	Early indicator	Response
Site traffic unlike the calibration corpus	Abstention rate climbs above the calibrated 9%	Recalibrate on local traffic; this is the designed signal
Analyst alert fatigue	Alerts per shift exceed agreed budget	Raise alpha, tighten severity gating, tune per class
Throughput below the site's link	Dropped-record counter rises	Add shards; report the ceiling honestly rather than degrade silently
Evidence workflow not adopted	Chain never verified by an operator	The verification step belongs in the incident runbook, not in the UI alone

Table 29. What would make a pilot fail, and how we would know early

CHAPTER 15

Risk register

ID	Risk	Type	Likelihood / impact	Mitigation
R1	Model trained on one network misjudges another	Technical	High / High	Abstention surfaces the drift; calibration on local traffic is a required deployment step, not an option
R2	Throughput below a 1 Gbps link	Technical	Certain / Medium	Sharding today; compiled fast path on the roadmap; the measured ceiling is stated to the customer before purchase
R3	HMAC key compromise voids evidence integrity	Security	Low / High	Hardware key custody and public-key signing (roadmap priority 4); documented as a limit until then
R4	No authentication on the console	Security	Medium / Medium	Deployment assumes an access-controlled enclave; roles are on the roadmap for multi-team sites
R5	Dictionary-based DGA families evade detection	Technical	Certain / Low	Stated openly (AUC 0.69 to 0.75); needs longer real captures and a richer language model
R6	Slow, diffuse insider activity	Technical	Medium / High	Per-flow evidence retained alongside host-window state, the direct consequence of exp10
R7	Sparse evaluation support for exfiltration and DGA heads	Evaluation	Certain / Medium	Support is published beside every score; pilot data is the remedy
R8	Operator does not adopt the evidence workflow	Adoption	Medium / Medium	Verification built into the incident runbook and the console's primary action
R9	Procurement timelines in this sector are long	Commercial	High / Medium	Zero-licence core lowers the approval bar; pilots proceed without a purchase decision
R10	Team continuity after the hackathon	Organisational	Medium / High	Everything is in one repository with 290 tests and reproduction commands; no undocumented knowledge is required to continue

Table 30. Risk register

CHAPTER 16

Compliance, standards and intellectual property

16.1 Indian legal and regulatory context

Instrument	What it requires	How EKAGRA relates to it
IT Act 2000, Section 70A (amended 2008)	Establishes NCIIPC as the national nodal agency for critical information infrastructure protection	Defines the customer and the sectors in Chapter 11
CERT-In Directions under Section 70B, 28 April 2022	Mandates enabling logs of ICT systems and maintaining them securely for a rolling 180 days within Indian jurisdiction, to be furnished when an incident is reported	Directly relevant. The hash-chained evidence log is a securely maintained record whose integrity can be demonstrated rather than asserted, and it never leaves Indian jurisdiction because it never leaves the enclave
CERT-In incident reporting	Reporting of specified incidents within six hours	Alerts carry severity, confidence and evidence bundles, which shortens the preparation of a report
NCIIPC guidelines for protection of critical information infrastructure	Segmentation, monitoring and controlled data flows	Designed for exactly the segmented, one-way topology those guidelines encourage

Table 31. Indian legal and regulatory context

16.2 Technical standards used

- **FIPS 180-4** for SHA-256 and **RFC 2104** for HMAC: standard primitives, no bespoke cryptography.
- **RFC 9000** and **RFC 9001** for QUIC and QUIC-TLS: Initial packet protection uses published keys, which is what makes metadata-only QUIC analysis legitimate rather than a decryption workaround.
- **MITRE ATT&CK** for threat-stage vocabulary, so that severity weights map to a recognised kill-chain position rather than to our own taxonomy.
- **CVSS** and **NIST SP 800-30** for the principle that impact and likelihood are separate axes (Chapter 5.6).
- **JA4** for TLS client fingerprinting, chosen over JA3 on measured grounds.

16.3 Intellectual property and licensing

- The implementation is our own work. Third-party dependencies are standard open-source libraries, used unmodified.
- CIC-IDS2017 and its corrected re-extraction are used under CC-BY-4.0 with attribution; neither is redistributed in our repository.
- Our own capture is personal traffic and is **not** redistributable; every finding derived from it is reproducible on any capture the reader controls.
- No patent is claimed. The contribution we would defend is the measurement and the method, both of which are more valuable published than held.

16.4 Data protection

The sensor processes traffic metadata, not content, and writes no payload to disk. Evidence bundles contain feature vectors, decisions and hashes; they do not contain packet contents. Nothing is transmitted outward, which is a structural rather than a policy guarantee: the detection path cannot open a socket, and a test enforces it.

CHAPTER 17

Impact and national alignment

17.1 Who benefits, and how

Stakeholder	Benefit	Evidence
NTRO and NCIIPC	Detection inside enclaves that currently run blind, with alerts that stand up as evidence	Ch 5, Ch 7
Critical-infrastructure operators	Visibility into isolated control networks without creating an inbound path	Ch 4.1, Ch 14
SOC analysts	Fewer unqualified alerts; each alert explains itself and can be proved	Ch 6, Ch 7
Auditors and incident responders	A log whose integrity is demonstrable, supporting the 180-day obligation	Ch 16
The research community	A measured answer to a question the literature had not asked, with published refutations	Ch 9
Indian industry	A zero-licence, indigenous alternative to recurring foreign subscriptions	Ch 13

Table 32. Who benefits, and how

17.2 National and sustainable-development alignment

- **Atmanirbhar Bharat and Make in India:** no foreign cloud dependency, no outbound telemetry, no recurring licence in foreign currency.
- **Digital India:** strengthens the trust layer beneath public digital infrastructure by protecting the networks that carry it.
- **SDG 9 (industry, innovation and infrastructure):** protects the infrastructure on which industry depends.
- **SDG 16 (peace, justice and strong institutions):** evidence that cannot be silently altered supports accountable investigation.

17.3 An analyst's day, before and after

Today, behind a diode	With EKAGRA
A detector trained on two-way data misses most attacks, and nothing reveals that it is failing	A detector trained on exactly what the tap delivers, with a measured cost of that constraint
Every low-confidence guess becomes an alert to chase	Weak evidence is marked as an abstention and counted, not raised as an alarm
"Why did it fire?" has no answer beyond a score	Each alert carries its observed features, the deciding model and the decision path
The alert log could have been edited; nobody can prove otherwise	One action re-derives the whole chain in the browser, independently of the server

Table 33. An analyst's day, before and after



PART IV

Execution, limitations and conclusion

CHAPTER 18

Project execution

18.1 How the work was organised

Role	Responsibility in this project
Detection and features	Visibility profiling, host-window and protocol features, detector heads
Data and experiments	Corpus preparation, pre-registration, experiment runs, verdict records
Systems and performance	Streaming pipeline, sharding, throughput measurement, packet parsers
Evidence and interface	Bundle format, hash chain, API, air-gapped console
Documentation and submission	This report, the deck, the demonstration, compliance mapping

Table 34. How the work was organised Team members are named on the certificate page. Roles overlapped in practice; the split above describes primary ownership.

18.2 Working method

- **Predictions before runs.** Every experiment file states what we expect before it is executed for the first time, and the run prints the verdicts.
- **A control for every claim.** The discipline that cost us our headline claim (condition G) is the same discipline that makes the surviving claims credible.
- **Tune on the metric you report.** A companion project of ours violated this and published a result that was wrong in its own favour's opposite direction; the lesson is applied here by reporting operating-point metrics alongside AUC.
- **Record every knob in the results payload,** so a published row can be regenerated by the script that produced it.
- **Correct errors that ran against us,** not only the flattering ones.

18.3 Effort profile

63 modules	14,253 lines of code	42 pre-registered predictions	10 experiments run
---------------	-------------------------	----------------------------------	-----------------------

CHAPTER 19

Limitations and future scope

19.1 Limitations, in full

- **1 Gbps is not reached.** Measured throughput is 610 to 672 Mbps.
- **Packet-size and timing sequence features are not implemented**, although the problem statement names them beside fingerprints. This is the clearest remaining gap and is priority one.
- **Dictionary-based DGA families are weak** (AUC 0.69 to 0.75).
- **Evidence integrity depends on a key held in the enclave**; there is no external anchor or asymmetric signature yet.
- **No authentication or authorisation** on the console: a recorded scope decision that assumes an already-restricted enclave.
- **Sharded output is not bit-exact**: 8 to 21 cells per configuration differ from a single process.
- **Evaluation support is thin for two heads** (13 test cells for exfiltration, 53 for DGA).
- **Tested on public corpora and our own capture**, not yet on a vendor diode or a live critical-infrastructure network.
- **1-RTT QUIC payloads remain out of reach**, and always will be without keys; only the Initial handshake is analysed.

19.2 Roadmap

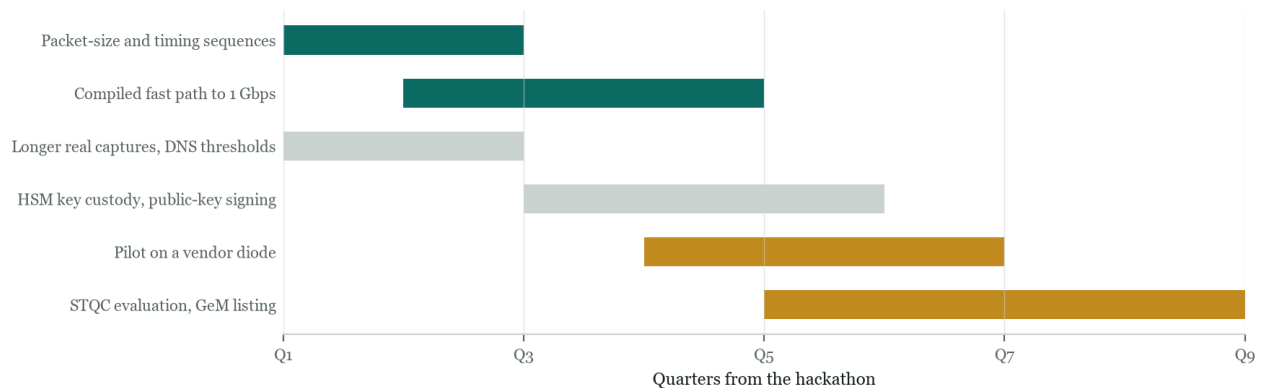


Figure 15. Sequence and dependencies. Teal items are engineering we can complete ourselves; amber items need an external partner or evaluator.

Priority	Work	Why it is next
1	Packet-size and timing sequence features	Named in the problem statement; the packet path now makes them possible, and the old reason for omitting them is obsolete
2	Compiled fast path for the hot loop	Closes 610 to 672 Mbps to line rate without changing the method
3	Longer real captures for DNS thresholds	Six minutes of traffic yields too few distinct benign names to set a 1% false-positive threshold; the 99th percentile is effectively the maximum
4	HSM key custody and public-key signing	Removes the one adversary in the threat model who currently wins
5	Pilot on vendor diode hardware	Confirms behaviour on the transport the deployment actually uses
6	Independent evaluation and procurement listing	Converts a working system into something an operator is permitted to buy
7	Analyst roles and multi-team access	Needed once more than one team shares a sensor

Table 35. Roadmap

CHAPTER 20

Conclusion

Threat detection behind a one-way link does not have to be a weaker copy of ordinary detection. On 877,801 real flows, a sensor that keeps sixteen aggregates of per-host behaviour over a sixty-second window scores 0.9810 binary F1 on one-way traffic, where a conventionally trained detector on the same tap falls to 0.6903 and a full two-way model reaches 0.9793. The constraint that looked like the problem - the missing direction - turned out not to be the cause of the loss at all.

Around that measurement we built a complete system: six detector heads covering the threat classes the problem statement names, severity separated from confidence, conformal abstention for the cases where an unverifiable guess is worse than silence, tamper-evident evidence that an analyst re-derives in an air-gapped browser, and an architecture whose read-only guarantee is enforced by its own build. It runs on a commodity server, carries no licence fee, and sends nothing outward.

We also measured its limits, and we report them in the same voice as its strengths: 610 to 672 Mbps rather than the 1 Gbps we once claimed; dictionary-based generated domains that our DNS features cannot separate; an evidence guarantee that a stolen key would void; two heads evaluated on very few cases. Seventeen of our forty-two pre-registered predictions were refuted, including the claim this project began with, and all seventeen are printed in this report.

That last point is the one we would ask an evaluator to weigh. A system whose authors can show which of their own beliefs the evidence destroyed is a system whose surviving claims mean something. On a network with no return path, where no one can tell the sensor it is wrong, that is the only kind of claim worth deploying.

References

- [1] I. Sharafaldin, A. H. Lashkari, A. A. Ghorbani. Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization. ICISSP, 2018.
- [2] G. Engelen, V. Rimmer, W. Joosen. Troubleshooting an Intrusion Detection Dataset: the CICIDS2017 Case Study. IEEE Security and Privacy Workshops (WTMC), 2021. doi:10.1109/SPW53761.2021.00009
- [3] H. Huang, S. Bois, T. Marchioro. Corrected CICFlowmeter Datasets: CIC-IDS 2017 and InSDN. Zenodo, record 22016274, CC-BY-4.0. doi:10.5281/zenodo.22016274
- [4] Canadian Institute for Cybersecurity. Intrusion detection evaluation dataset (CIC-IDS2017). unb.ca/cic/datasets/ids-2017.html
- [5] R. Sommer, V. Paxson. Outside the Closed World: On Using Machine Learning for Network Intrusion Detection. IEEE Symposium on Security and Privacy, 2010.
- [6] D. Arp, E. Quiring, F. Pendlebury, et al. Dos and Don'ts of Machine Learning in Computer Security. USENIX Security, 2022.
- [7] V. Vovk, A. Gammerman, G. Shafer. Algorithmic Learning in a Random World. Springer, 2005.
- [8] A. N. Angelopoulos, S. Bates. A Gentle Introduction to Conformal Prediction and Distribution-Free Uncertainty Quantification. arXiv:2107.07511, 2021.
- [9] P. Flajolet, E. Fusy, O. Gandouet, F. Meunier. HyperLogLog: the analysis of a near-optimal cardinality estimation algorithm. AofA, 2007.
- [10] G. Cormode, S. Muthukrishnan. An improved data stream summary: the count-min sketch and its applications. Journal of Algorithms, 2005.
- [11] T. Chen, C. Guestrin. XGBoost: A Scalable Tree Boosting System. KDD, 2016.
- [12] FoxIO. JA4+ network fingerprinting suite. github.com/FoxIO-LLC/ja4
- [13] J. Iyengar, M. Thomson (eds). RFC 9000: QUIC, a UDP-Based Multiplexed and Secure Transport. IETF, 2021.
- [14] M. Thomson, S. Turner (eds). RFC 9001: Using TLS to Secure QUIC. IETF, 2021.
- [15] H. Krawczyk, M. Bellare, R. Canetti. RFC 2104: HMAC, Keyed-Hashing for Message Authentication. IETF, 1997.
- [16] NIST. FIPS 180-4, Secure Hash Standard. 2015.
- [17] NIST. SP 800-30 Rev. 1, Guide for Conducting Risk Assessments. 2012.
- [18] FIRST. Common Vulnerability Scoring System v3.1 Specification.
- [19] D. Plohmann, K. Yakdan, M. Klatt, J. Bader, E. Gerhards-Padilla. A Comprehensive Measurement Study of Domain Generating Malware. USENIX Security, 2016.
- [20] Government of India, Ministry of Electronics and IT. CERT-In Directions under sub-section (6) of section 70B of the IT Act, 2000. No. 20(3)/2022-CERT-In, 28 April 2022.
- [21] National Critical Information Infrastructure Protection Centre (a unit of NTRO). About NCIIPC and identified critical sectors. nciipc.gov.in
- [22] Press Information Bureau, Government of India. CERT-In annual figures for 2025: 29.44 lakh incidents handled, 1,530 alerts, 231 empanelled audit organisations.
- [23] MarketsandMarkets. Network Detection and Response Market, global forecast to 2030 (\$3.68B in 2025 to \$5.82B in 2030, 9.6% CAGR).
- [24] MarketsandMarkets. Data Diode Market, global forecast to 2031 (\$0.56B in 2026 to \$0.77B in 2031, 6.6% CAGR).
- [25] Smart India Hackathon 2026, problem statement SIH26145, National Technical Research Organisation. sih.gov.in

APPENDIX A

APPENDIX A: Glossary and full forms

Term	Expansion and meaning
Abstention	the sensor declining to assign a label because the evidence does not support one
AUC	Area Under the ROC Curve; 1.0 is perfect separation, 0.5 is a coin flip
C2	Command and Control: the channel an attacker uses to direct infected hosts
CERT-In	Indian Computer Emergency Response Team
CIC-IDS2017	Canadian Institute for Cybersecurity Intrusion Detection System dataset, 2017
CII	Critical Information Infrastructure
Conformal prediction	a method that converts model scores into predictions with a distribution-free error guarantee
CVSS	Common Vulnerability Scoring System
Data diode	hardware permitting data flow in exactly one direction
DDoS	Distributed Denial of Service
DGA	Domain Generation Algorithm: malware that generates domain names to reach its controller
DNS	Domain Name System
ECE	Expected Calibration Error: the gap between stated confidence and observed accuracy
Exfiltration	unauthorised transfer of data out of a network
F1 (binary / macro)	harmonic mean of precision and recall; macro averages it over classes so rare classes count equally
Flow	a group of packets sharing a five-tuple within timeouts
GeM	Government e-Marketplace, India's public procurement platform
HLL	HyperLogLog, a fixed-memory distinct-count estimator
HMAC	Hash-based Message Authentication Code: a keyed hash
Host window	per-host state aggregated over a fixed time window (60 s here)
HSM	Hardware Security Module
IAT	Inter-Arrival Time
IDS / NIDS	Intrusion Detection System / Network Intrusion Detection System
JA3 / JA4	fingerprints computed from a TLS client's handshake
Mondrian conformal	conformal prediction calibrated separately per class
NCIIPC	National Critical Information Infrastructure Protection Centre, a unit of NTRO
NDR	Network Detection and Response
NTRO	National Technical Research Organisation
OT	Operational Technology: the control systems behind industrial processes
pcap	packet capture file format
Pre-registration	fixing a prediction in writing before the experiment runs

Term	Expansion and meaning
QUIC	a UDP-based transport underlying HTTP/3
SHA-256	Secure Hash Algorithm, 256-bit output
SPAN port	Switched Port Analyser: a switch port that mirrors traffic
SOC	Security Operations Centre
SPOC	Single Point of Contact, the institutional coordinator for SIH
STQC	Standardisation Testing and Quality Certification, an Indian evaluation body
TAM / SAM / SOM	Total, Serviceable and Obtainable market
TLS	Transport Layer Security
Visibility profile	the set of observations a given sensor placement can actually make
XGBoost	eXtreme Gradient Boosting, a gradient-boosted tree library

Table 36. APPENDIX A: Glossary and full forms

APPENDIX B

APPENDIX B: Problem-statement compliance matrix

Requirement in SIH26145	How it is met	Where	Status
Strictly read-only input; no return path, live query or inline block	One-way pipeline; a build-failing test forbids network clients in the detection path; read-only API surface	Ch 4, Ch 10.2	Met
TLS and QUIC analysed from metadata only	JA4 from reassembled handshakes; QUIC Initial parsed with published keys; payload bytes never reach feature code	Ch 5.4	Met
Incremental processing with bounded latency	Single-pass streaming, 60 s window plus 15 s lateness	Ch 4.4	Met
(a) Volumetric and protocol DDoS	volumetric head on destination-side host-window features	Ch 5.5	Met
(b) Command-and-control beaconing	beacon head on inter-arrival regularity and peer concentration	Ch 5.5	Met
(c) DGA and DNS tunnelling, with entropy and n-gram analysis of query names including length anomalies	dga head on character entropy, causal bigram rarity, label length and digit ratio	Ch 5.4, 9.6	Met; dictionary families weak
(d) Malware in encrypted sessions via JA3/JA4 fingerprints	encrypted head on JA4 rarity and novelty	Ch 5.4	Met
(d) ... and packet-size and timing patterns	not implemented; the packet path now makes it possible and it is roadmap priority one	Ch 19	Gap
(e) Reconnaissance and scanning	scan head on fan-out cardinality per source	Ch 5.5	Met
(f) Data exfiltration	exfil head on outbound volume against a per-host decayed baseline	Ch 5.5	Met; 13 test cells
Alerts carry severity and confidence	severity independent of confidence; conformal confidence with abstention	Ch 5.6, Ch 6	Met

Table 37. APPENDIX B: Problem-statement compliance matrix

APPENDIX C

APPENDIX C: Reproduction guide

Everything in Part II can be regenerated from the repository. Datasets are not redistributed: they are third-party and large.

```
cd ekagra/backend
pip install -e .

python -m pytest tests/ -q                # 290 tests
python experiments/exp04_forward_features.py # the headline ablation
python experiments/exp10_low_rate_diffuse.py # the stress test
python experiments/exp11_dga_real_benign.py --capture <file.pcapng>
python demo.py                          # API + console on :8000
python analyse_pcap.py <capture.pcapng>   # packet path on a capture
```

- Place the corrected CIC-IDS2017 re-extraction (Zenodo 22016274) under backend/data/.
- Each experiment prints its pre-registered predictions with verdicts and writes them to backend/results/exp*_verdicts.json.
- The console also runs with no server: open frontend/index.html directly and it uses the bundled snapshot.
- Figures in this report are produced by experiments/make_figures.py and by submission/ekagra_report/figures.py.

APPENDIX D

APPENDIX D: Evidence bundle schema

```
{
  "seq": 90394,
  "ts": 1725638400.0,
  "threat_class": "ddos",
  "decision": "ALERT",           // or ABSTAIN
  "confidence": 1.0,             // conformal, per class
  "severity": {"level": "high", "score": 0.70},
  "observed": {"window": 59, "host": "105.35.144.90",
               "flows": 1, "peers": 0},
  "features": { ... 16 host-window + 9 protocol values ... },
  "model": "ba23cefc9789cecc...", // fingerprint of the deciding model
  "decision_path": [ ... ],
  "prev_hash": "b2882319284cd5ed...",
  "entry_hash": "5450847e8565c8d7...", // SHA-256 of the canonical form
  "hmac": "5644012b36402abdc356..." // HMAC-SHA256, key held in enclave
}
```

- entry_hash covers the canonical form of every field above it, including prev_hash, which is what makes the record a chain rather than a list.
- Severity is deliberately **not** hashed: it is a pure function of threat_class and features, both already committed, so hashing it would add a field that can never disagree while invalidating every record written before it existed.
- Canonical form fixes key order and float precision, rejects non-finite values, and treats negative zero as zero (Ch 7.2).

APPENDIX E

APPENDIX E: The pre-registered prediction register

Forty-two predictions across ten experiments; seventeen refuted. The refuted set is listed in full in Chapter 9.7 with outcomes. The register below is the summary by experiment, as printed by the runs themselves into `results/exp*_verdicts.json`.

Experiment	Focus	IDs	Held	Refuted
exp01	Reduced visibility on generated traffic	P1 to P4	0	4
exp03	First real-corpus run	S1 to S3	2	1
exp04	Attribution with controls	T1 to T3	3	0
exp05	Streaming versus exact batch	U1 to U4	4	0
exp06	Full packet pipeline	V1 to V4	3	1
exp07	Sharding and line rate	W1 to W5	1	4
exp08	Evidence chain and console	X1 to X3	3	0
exp09	Six heads versus one multiclass model	Y1 to Y4	2	2
exp10	Low-rate diffuse attacks	Z0 to Z5	4	2
exp11	DGA against real benign names	D1 to D6	3	3
Total			25	17

Table 38. APPENDIX E: The pre-registered prediction register

APPENDIX F

APPENDIX F: Anticipated questions

Q. Why not simply deploy Suricata or Zeek behind the diode?

They can run passively, but a large share of signatures and analysers depend on server responses, and rule updates require the network path the enclave does not have. We measured what losing the replies costs a trained detector: 0.9793 to 0.6903 binary F1.

Q. Your 0.98 looks too high for CIC-IDS2017, which is a flawed dataset.

We use the corrected re-extraction, exclude source and destination addresses, and split temporally. We also publish the experiment that breaks our own number: under low-rate diffuse attacks, host-window-alone falls to 0.28 macro F1.

Q. Is this not just XGBoost with extra steps?

The model is deliberately standard. The contribution is what it is fed (visibility-matched host-window state), what it refuses to say (calibrated abstention), and what it can prove afterwards (sealed evidence).

Q. What does an abstention mean operationally?

It means the evidence available to this sensor does not support a confident label. It is 9.11% of cases, they are logged rather than dropped, and a rising rate is the drift signal a diode deployment otherwise has no way to receive.

Q. What exactly does the evidence chain prove?

That no alert was edited, deleted or reordered after sealing - including by the operator - unless the HMAC key was stolen. That single exception is stated in the threat model rather than glossed over.

Q. 672 Mbps is not 1 Gbps. Is that a failure?

It is a measured gap that we state openly, having retracted our own earlier 1 Gbps claim. Sharding reaches 108,938 packets per second; line rate at 700-byte packets needs 178,571. A compiled fast path is the route, and it is on the roadmap rather than in the results.

Q. How do you know the sensor is genuinely read-only?

A test parses every module in the detection path and fails the build if any network client is imported. The guarantee is enforced by the build, not asserted in a document.

Q. What is the biggest technical weakness?

Packet-size and timing sequence features are not implemented, and the problem statement names them. Second is dictionary-based DGA, where AUC falls to 0.69.

Q. What is the business risk you worry about most?

Procurement timelines. The zero-licence core is designed partly to let a pilot proceed without a purchase decision, so that technical value can be demonstrated before commercial commitment.

Q. Why should an evaluator trust these numbers?

Because we publish the ones that went against us. Seventeen of forty-two pre-registered predictions were refuted, including the claim the project began with, and the verdicts are written by the experiment runs rather than by us.